

Hiestand, Brand, Loughran, P.A.

SOC 2[®] TYPE 2 REPORT ON CONTROLS RELEVANT TO SECURITY, AVAILABILITY, PROCESSING INTEGRITY, AND CONFIDENTIALITY FOR THE ONLINE TRANSACTION PROCESSING SYSTEM

THE CBORD GROUP, INC.

AUGUST 1, 2024 TO JULY 31, 2025



An Affiliate Company of
360.ADVANCED

THE CBORD GROUP, INC.

Table of Contents

SECTION 1: INDEPENDENT SERVICE AUDITOR'S REPORT	1
SECTION 2: MANAGEMENT'S ASSERTION	6
SECTION 3: DESCRIPTION OF THE SYSTEM	9
SCOPE OF REPORT AND DISCLOSURES	10
Overview	10
Trust Services Categories and Related Criteria	10
Scope	11
Sub-Service Organization	12
Significant Changes during the Examination Period	12
Subsequent Events	12
System Incidents	12
Using the Work of the Internal Audit Function	12
OVERVIEW OF OPERATIONS AND THE SYSTEM	13
Company Overview and Background	13
Overview of the Online Transaction Processing System	13
Principal Service Commitments and System Requirements	14
OVERVIEW OF RELEVANT INFRASTRUCTURE	16
Infrastructure	16
Software	17
People	18
Procedures	19
Data	24
RELEVANT ASPECTS OF CONTROL ENVIRONMENT, RISK ASSESSMENT, INFORMATION AND COMMUNICATIONS SYSTEMS, AND MONITORING	26
Control Environment	26
Risk Assessment	28
Information and Communication Systems	29
Monitoring	30
CATEGORIES, CRITERIA, AND RELATED CONTROLS	31
COMPLEMENTARY CONTROL CONSIDERATIONS	32
SECTION 4: CATEGORIES, CRITERIA, CONTROL DESCRIPTIONS, RELATED CONTROLS AND TESTS OF OPERATING EFFECTIVENESS	33
INFORMATION PROVIDED BY THE SERVICE AUDITOR	34
Introduction	34
Tests of Operating Effectiveness	34
Types of Tests Performed	35
Procedures for Assessing Completeness and Accuracy of IPE	35
Sampling Methodology	36
CATEGORIES, CRITERIA, AND RELATED CONTROLS	37
Security (Common Criteria to All Categories)	37
Availability Category and Criteria	98
Processing Integrity Category and Criteria	104
Confidentiality Category and Criteria	112
SECTION 5: INFORMATION PROVIDED BY THE SERVICE ORGANIZATION THAT IS NOT COVERED BY THE SERVICE AUDITOR'S REPORT	115
Management's Responses to the Testing Exceptions	116
Control Mapping to Essential Eight Requirements	117

SECTION 1:

INDEPENDENT SERVICE AUDITOR'S REPORT

The CBORD Group Inc
For AWS
Confidential

Hiestand, Brand, Loughran, P.A.

INDEPENDENT SERVICE AUDITOR'S REPORT

To The CBORD Group, Inc.:

Scope

We have examined the accompanying description of The CBORD Group, Inc.'s ("CBORD") Online Transaction Processing system throughout the period August 1, 2024 to July 31, 2025, based on the criteria for a description of a service organization's system in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance — 2022)* (description criteria), and the suitability of the design and operating effectiveness of controls stated in the description throughout the period August 1, 2024 to July 31, 2025, to provide reasonable assurance that CBORD's service commitments and system requirements were achieved based on the trust services criteria relevant to Security, Availability, Processing Integrity, and Confidentiality (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus — 2022)* in AICPA, *Trust Services Criteria*.

CBORD uses the following subservice organizations in support of its Online Transaction Processing Services system.

- Amazon Web Services, Inc. ("AWS") is utilized for cloud hosting services.
- Okta, Inc. ("Okta") is utilized for identity and access management.

The description indicates that complementary sub-service organization controls that are suitably designed and operating effectively are necessary, along with controls at CBORD, to achieve CBORD's service commitments and system requirements based on the applicable trust services criteria. The description presents CBORD's controls, the applicable trust services criteria, and the types of complementary sub-service organization controls assumed in the design of CBORD's controls. The description does not disclose the actual controls at the sub-service organizations. Our examination did not include the services provided by the sub-service organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary sub-service organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at CBORD, to achieve CBORD's service commitments and system requirements based on the applicable trust services criteria. The description presents CBORD's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of CBORD's controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such controls.

The information included in Section 5, *Information provided by the Service Organization Not Covered by the Service Auditor's Report*, is presented by management of CBORD to provide additional information and is not a part of the description. Management's responses to the testing exceptions and control mapping to essential eight requirements included in Section 5 have not been subjected to the procedures applied in the examination of the description, and of the suitability of the design and operating effectiveness of controls to CBORD. CBORD's service commitments and system requirements based on the applicable trust services criteria, and accordingly, we express no opinion on it.

Service Organization's Responsibilities

CBORD's management is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that CBORD's service commitments and system requirements were achieved. CBORD's management has provided the accompanying assertion titled "Management of The CBORD Group, Inc.'s Assertion" included in Section 2 of this report about the description and the suitability of design and operating effectiveness of controls stated therein. Management is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust

services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of the controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusion about the suitability of the design or operating effectiveness of controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested, and the nature, timing, and results of those tests are presented in Section 4 of this report.

Controls That Were Not Tested During the Period

CBORD's description of its Online Transaction Processing system discusses its vendor onboarding procedures, which includes the control implemented and operated to define terms and conditions and the responsibilities for parties with access to confidential information within executed contracts. However, during the period August 1, 2024 to July 31, 2025, CBORD did not onboard any vendors that would warrant the operation of the related control.

Because the control described above was not required to operate during the period, we did not test the operating effectiveness of that control to evaluate the following trust services criteria:

- CC1.1 - COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.
- CC2.3 - COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.
- CC9.2 The entity assesses and manages risks associated with vendors and business partners.

Opinion

In our opinion, in all material respects:

- a. the description presents CBORD's Online Transaction Processing system that was designed and implemented throughout the period August 1, 2024 to July 31, 2025, in accordance with the description criteria;
- b. the controls stated in the description were suitably designed throughout the period August 1, 2024 to July 31, 2025, to provide reasonable assurance that CBORD's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the sub-service organization and user entities applied the complementary controls, if applicable, assumed in the design of CBORD's controls throughout that period; and
- c. the controls stated in the description operated effectively throughout the period August 1, 2024 to July 31, 2025, to provide reasonable assurance that CBORD's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary sub-service organization and complementary user entity controls, if applicable, assumed in the design of CBORD's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of CBORD, user entities of CBORD's Online Transaction Processing system during some or all of the period August 1, 2024 to July 31, 2025, business partners of CBORD subject to risks arising from interactions with the Online Transaction Processing system, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, sub-service organizations, and other parties
- Internal control and its limitations
- If applicable, complementary user entity controls and complementary sub-service organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements

- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.

Hiestand, Brand, Ayman) PA.

October 30, 2025
St. Petersburg, Florida

The CBORD Group Inc
For AWS
Confidential

SECTION 2:

MANAGEMENT'S ASSERTION

The CBORD Group Inc
For AWS
Confidential

MANAGEMENT OF CBORD GROUP, INC.'S ASSERTION

October 30, 2025

We have prepared the accompanying description of The CBORD Group, Inc.'s ("CBORD") Online Transaction Processing system throughout the period August 1, 2024 to July 31, 2025, based on the criteria for a description of a service organization's system in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance — 2022)* in AICPA, *Description Criteria* (description criteria). The description is intended to provide report users with information about the Online Transaction Processing system that may be useful when assessing the risks arising from interactions with CBORD's system, particularly information about system controls that CBORD has designed, implemented, and operated to provide reasonable assurance that our service commitments and system requirements were achieved based on the trust services criteria relevant to Security, Availability, Processing Integrity, and Confidentiality (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus — 2022)* in AICPA, *Trust Services Criteria*.

CBORD uses the following subservice organizations in support of its Online Transaction Processing Services system.

- Amazon Web Services, Inc. ("AWS") is utilized for cloud hosting services.
- Okta, Inc. ("Okta") is utilized for identity and access management.

The description indicates that complementary sub-service organization controls that are suitably designed and operating effectively are necessary, along with controls at CBORD, to achieve CBORD's service commitments and system requirements based on the applicable trust services criteria. The description presents CBORD's controls, the applicable trust services criteria, and the types of complementary sub-service organization controls assumed in the design of CBORD's controls. The description does not disclose the actual controls at the sub-service organizations.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at CBORD, to achieve CBORD's service commitments and system requirements based on the applicable trust services criteria. The description presents CBORD's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of CBORD's controls.

We confirm, to the best of our knowledge and belief, that

- a. the description presents CBORD's Online Transaction Processing system that was designed and implemented throughout the period August 1, 2024 to July 31, 2025, in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period August 1, 2024 to July 31, 2025, to provide reasonable assurance that CBORD's service commitments and system requirements would be achieved based on the applicable trust services criteria, if our controls operated effectively throughout the period, and if the sub-service organization and user entities applied the complementary controls, if applicable, assumed in the design of CBORD's controls throughout that period.
- c. the controls stated in the description operated effectively throughout the period August 1, 2024 to July 31, 2025, to provide reasonable assurance that CBORD's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary sub-service organization controls and complementary user entity controls, if applicable, assumed in the design of CBORD's controls operated effectively throughout that period.

- d. our description of Online Transaction Processing system discusses CBORD's vendor onboarding procedures, which includes the controls to define confidentiality and breach notification requirements within executed contracts. However, during the period, August 1, 2024 to July 31, 2025 CBORD did not onboard any vendors that would warrant the operation of the related control.

/s/ The CBORD Group, Inc.

David Shaw - Chief Information Security Officer

The CBORD Group Inc
For AWS
Confidential

SECTION 3:

DESCRIPTION OF THE SYSTEM

The CBORD Group Inc
For AWS
Confidential

SCOPE OF REPORT AND DISCLOSURES

Overview

This description of the system of controls provided by The CBORD Group, Inc.'s ("CBORD") management, as related to Statement on Standards for Attestation Engagements No. 21 '*Direct Examination Engagements*', specifically AT-C Section 105, '*Concepts Common to All Attestation Engagements*' and AT-C Section 205, '*Assertion – Based Examination Engagements*,' considers the direct and indirect impact of risks and controls that CBORD's management has determined are likely to be relevant to its user entities' internal controls intended to mitigate risks related to security, availability, processing integrity, confidentiality, or privacy.

Trust Services Categories and Related Criteria

The five attributes of a system are known as *categories*, and they are defined as follows:

- **Security:** Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to meet its objectives.

Security refers to the protection of

- i. information during its collection or creation, use, processing, transmission, and storage and
- ii. systems that use electronic information to process, transmit or transfer, and store information to enable the entity to meet its objectives. Controls over security prevent or detect the breakdown and circumvention of segregation of duties, system failure, incorrect processing, theft or other unauthorized removal of information or system resources, misuse of software, and improper access to or use of, alteration, destruction, or disclosure of information.

- **Availability:** Information and systems are available for operation and use to meet the entity's objectives.

Availability refers to the accessibility of information used by the entity's systems, as well as the products or services provided to its customers. The availability objective does not, in itself, set a minimum acceptable performance level; it does not address system functionality (the specific functions a system performs) or usability (the ability of users to apply system functions to the performance of specific tasks or problems). However, it does address whether systems include controls to support accessibility for operation, monitoring, and maintenance.

- **Processing Integrity:** System processing is complete, valid, accurate, timely, and authorized to meet the entity's objectives.

Processing integrity refers to the completeness, validity, accuracy, timeliness, and authorization of system processing. Processing integrity addresses whether the system achieves the aim or purpose for which they exist and whether they perform their intended functions in an unimpaired manner, free from error, delay, omission, and unauthorized or inadvertent manipulation. Because of the number of systems used by an entity, processing integrity is usually only addressed at the system or functional level of an entity.

- **Confidentiality:** Information designated as confidential is protected to meet the entity's objectives.

Confidentiality addresses the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives. Information is confidential if the custodian of the information is required to limit its access, use, and retention and restrict its disclosure to defined parties (including those who may otherwise have authorized access within its system boundaries). Confidentiality requirements may be contained in laws or regulations or in contracts or agreements

that contain commitments made to customers or others. The need for information to be confidential may arise for many different reasons.

Confidentiality is distinguished from privacy in that privacy applies only to personal information, whereas confidentiality applies to various types of sensitive information. In addition, the privacy objective addresses requirements regarding collection, use, retention, disclosure, and disposal of personal information. Confidential information may include personal information as well as other information, such as trade secrets and intellectual property.

- **Privacy:** Personal information is collected, used, retained, disclosed, and disposed to meet the entity's objectives.

Although the confidentiality criteria apply to various types of sensitive information, privacy applies only to personal information.

The privacy criteria are organized into eight categories:

- a. *Notice and communication of objectives.* The entity provides notice to data subjects about its objectives related to privacy.
- b. *Choice and consent.* The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to data subjects.
- c. *Collection.* The entity collects personal information to meet its objectives related to privacy.
- d. *Use, retention, and disposal.* The entity limits use, retention, and disposal of personal information to meet its objectives related to privacy.
- e. *Access.* The entity provides data subjects with access to their personal information for review and correction (including updates) to meet its objectives related to privacy.
- f. *Disclosure and notifications.* The entity discloses personal information, with the consent of the data subjects, to meet its objectives related to privacy. Notification of breaches and incidents is provided to affected data subjects, regulators, and others to meet its objectives related to privacy.
- g. *Quality.* The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet its objectives related to privacy.
- h. *Monitoring and enforcement.* The entity monitors compliance to meet its objectives related to privacy, including procedures to address privacy-related inquiries, complaints, and disputes.

The trust services criteria may be used when evaluating the suitability of the design and operating effectiveness of controls relevant to the security, availability, or processing integrity of information and systems, or the confidentiality or privacy of the information processed by the entity. As such, they may be used when evaluating whether the entity's controls were effective to meet the criteria relevant to any of those categories, either individually or in combination with controls in other categories.

Scope

The scope that management has determined appropriate for the Online Transaction Processing system includes the controls to meet the applicable trust services criteria. Management is responsible for the identification of risks associated with the system of controls, and for the design and operation of controls intended to provide reasonable assurance that the applicable trust services criteria would be met.

As part of its overall SOC 2® program, CBORD's management sets and determines the scope and timing of each report. This description of the system has been prepared by CBORD's management, headquartered in Ithaca, New York, to provide information on controls applicable to meet the trust services criteria for Security, Availability, Processing Integrity, and Confidentiality.

Sub-Service Organization

CBORD uses the following subservice organizations in support of its Online Transaction Processing Services system.

- Amazon Web Services, Inc. (“AWS”) is utilized for cloud hosting services.
- Okta, Inc. (“Okta”) is utilized for identity and access management.

Our examination did not extend to the services provided by the sub-service organizations, and we have not evaluated whether the controls management expects to be implemented at the sub-service organizations have been implemented or whether such controls were suitably designed or operating effectively throughout the examination period. CBORD receives and reviews the third-party reports for AWS and Okta annually, and monitors the services performed to determine whether operations and controls expected to be implemented are functioning correctly.

Significant Changes during the Examination Period

Management is not aware of any significant changes that occurred during the examination period.

Subsequent Events

Management is not aware of any relevant events that occurred subsequent to the period covered by management’s description included in Section 3 of this report through the date of the service auditor’s report that would have a significant effect on management’s assertion.

System Incidents

Management is not aware of any system incidents that (a) were the result of controls that were not suitably designed or operating effectively or (b) otherwise resulted in a significant failure in the achievement of one or more service commitments and system requirements during the period covered by management’s description included in Section 3 of this report.

Using the Work of the Internal Audit Function

The service auditor did not utilize any work of an Internal Audit function in preparing this report.

OVERVIEW OF OPERATIONS AND THE SYSTEM

Company Overview and Background

The CBORD Group, headquartered in Ithaca, New York, provides integrated technology solutions. More than 10,000 organizations in the United States, Canada, South Africa, the Middle East, Australia, and New Zealand use their products and services. Founded in 1975, CBORD has grown into a leading provider of integrated technology solutions used on campuses across the country, including college, university, K-12 healthcare, and senior living campuses, as well as business and industry accounts providing services across the continuum of care. CBORD delivers software and hardware solutions that aim to improve safety, accuracy, and satisfaction for users across industries, including housing, access control, food service, nutrition, commerce, and card systems.

CBORD operates as a unit of Roper Technologies, with systems installed in over 11,000 sites across the United States and over two million users.

Overview of the Online Transaction Processing System

CBORD provides the Online Transaction Processing System through its NetMenu, Odyssey Direct, GET, and MyPaymentsPlus applications hosted within its AWS environment.

NetMenu

NetMenu includes the following modules: CBORD Fusion, NetMenu Planner, NetMenu TrayCard, NetMenu TrayTicket, Selective Dining, Mobile Inventory, CBORD Patient, Room Service Choice, NetMenu Floor Stock, CBORD C-Store, CBORD Data Analytics, CBORD Hub, NetNutrition, NetRecipe, Tray Logistics, Menu Display Interface (MDI); and its customer-branded applications: CBORD School Technology (HST) Back of House (BOH), BluePrint Menu Management System®, Cycle Menu Management®, Sysco® eNutrition, NetIMPAC, and Menu Wizard+. NetMenu provides an integrated food production, inventory management, and menu planning solution to support retail and patient nutrition. Electronic vendor integration and integration into CBORD customer accounts payable, general ledger, and point-of-sale software allow CBORD customers to leverage current systems when interfacing with NetMenu. NetMenu enables customers to:

- Track food supply and inventory.
- Standardize recipes.
- Menu plan.
- Nutritionally analyze menus.
- Maintain purchasing compliance.
- Provide a single platform and vendor for compliance and tracking.
- Maintain diet-order compliance to ensure patient safety for meal served.
- Patient / Resident feeding.

Odyssey Direct

Through Odyssey Direct, university clients have the ability to establish a wide-ranging suite of services linked to a customized campus credential. This encompassing suite includes services such as card printing and credential management, photo capture, management of meal plans, debit and credit accounts, point-of-sale transactions for dining and retail, attendance tracking, as well as eligibility verification.

Furthermore, the use of campus card payments is seamlessly integrated into various aspects of university life. These payment capabilities extend to dining services, vending machines, laundry facilities, photocopying and printing services, parking facilities, university bookstores, e-commerce platforms, and even select off-campus dining establishments. A dedicated mobile application ensures round-the-clock accessibility, empowering university students with access to their account information and service details. Beyond the administrative aspects of managing their campus card account, students can leverage this application to peruse dining menus, place food orders, gain access to their rooms, and, when necessary, employ it for identification purposes.

GET

GET serves as a centralized, cloud-based platform tailored for organizations utilizing the CBORD card / cashless system, aimed at elevating the quality of service provided to their patrons, expanding patron engagement with the cashless program, and driving user involvement and revenue growth. GET offers an integrated experience that aligns with the expectations of today's students, particularly within the ever-evolving mobile landscape through the CBORD platform.

Within the GET platform, users have access to real-time balance information, transaction history, the capability to report a lost or found card, and the ability to make deposits using a credit card. Furthermore, GET's core features encompass food ordering, virtual card payment, mobile access, and a loyalty system. GET also supports integration with campus authentication systems and e-commerce merchant accounts for the acceptance of credit card payments.

MyPaymentsPlus

The MyPaymentsPlus application provides an online credit card and automated clearing house (ACH) payment service system that allows parents to make various secure payments to their K-12 students' MyPaymentsPlus account at any of the participating schools. This system can be used to cover things such as food service payments, online registrations, and other fees and activity items. Users process transactions using their credit cards and e-checks through the MyPaymentsPlus online application. The merchant organization can also process in-person payments via a secure admin portal.

Transaction processing within this system is principally controlled through customer elections that are established during a customer's initial setup on the system. Using parameters, transaction processing can be tailored to each customer's unique transaction processing requirements.

Other CBORD services are not included within the scope of this report. The accompanying description includes only the policies, procedures, and control activities at CBORD and does not include the policies, procedures, and control activities at any sub-service organizations.

Principal Service Commitments and System Requirements

CBORD's management designs its processes and procedures related to the Online Transaction Processing System to meet its objectives. Those objectives are based on the service commitments that CBORD's management makes to user entities, the laws and regulations that govern the provisioning of the Online Transaction Processing System and the financial, operational, and compliance requirements that CBORD has established for the services.

CBORD's principal service commitments and system requirements may be explicitly stated within Service Level Agreements and contracts or may be implicitly agreed to based on the nature of the industry in which they operate.

These commitments generally include the following:

Trust Services Category	Service Commitments	System Requirements
Security	➤ System access is granted to authorized personnel. ➤ Identification and remediation of security incidents / events. ➤ Maintain PCI-DSS compliance during the term of the Agreement.	➤ Logical access standards ➤ Employee provisioning and deprovisioning standards ➤ Access review standards ➤ Encryption standards ➤ Intrusion detection and prevention standards ➤ Risk and vulnerability management standards ➤ Configuration management standards ➤ Incident handling standards ➤ Change management standards ➤ Vendor management standards
Availability	➤ Maintain 99% availability or better per calendar month, excluding scheduled and emergency maintenance windows.	➤ System monitoring ➤ Backup and recovery standards
Processing Integrity	➤ CBORD's provision of the Online Transaction Processing System, including those related to the collection, use, processing, transfer, and disclosure of personal information to be in agreement with customer provided notes and consent.	➤ Data integrity standards ➤ Data input validation and monitoring ➤ Extensive report options
Confidentiality	➤ CBORD agrees that, without the prior written consent of an officer of the customer, it will neither disclose to others nor permit its officers or employees to disclose any technical or accounting data, proprietary information, or confidential business information of the customer. ➤ CBORD agrees to protect customer data with at least the same degree of care as it does its own Confidential Information. ➤ CBORD does not disclose confidential information to others without the prior written consent of the customer.	➤ Data classification ➤ Retention and destruction standards ➤ Data handling standards ➤ Internal confidentiality standards ➤ Information sharing standards

OVERVIEW OF RELEVANT INFRASTRUCTURE

The Online Transaction Processing system is comprised of the following components:

- Infrastructure – the physical structures, information technology (IT), and other hardware
- Software – the application programs and IT system software that supports application programs
- People – the personnel involved in the governance, operation, and use of a system
- Procedures – the automated and manual procedures
- Data – transaction streams, files, databases, tables, and output used or processed by the system

Infrastructure

The company utilizes AWS to provide the resources to host the Online Transaction Processing System. The production environments are located within the AWS US-EAST region, in northern Virginia. The US-East-1c availability zone is for primary data center hosting, and availability zone US-East-1d is used for disaster recovery. The applications supporting the Online Transaction Processing System are housed on servers running Windows operating systems (OS). SQL / Aurora and Oracle databases are utilized to support the backend of the applications. A Linux proxy is used to isolate the application servers from the Internet.

The company leverages the experience and resources of AWS to scale as necessary to meet current and future demand. However, the company is responsible for designing and configuring the Online Transaction Processing Systems architecture within AWS to meet the availability, security, and resiliency requirements.

The following describes the in-scope components supporting the Online Transaction Processing system:

System / Application	Description	Infrastructure
NetMenu	Integrated food production, inventory management, and menu planning solution to support retail and patient nutrition	<u>Hosting Platform:</u> Amazon EC2 <u>Operating Systems:</u> Amazon Linux 2023 Windows Server 2019 <u>Networking:</u> AWS Network Security Groups AWS WAF <u>Databases:</u> Oracle SE2
OdysseyDirect	Provides services linked to customized campus credentials, such as dining services, vending machines, laundry facilities, photocopying and printing services, parking facilities, university bookstores, and e-commerce platforms.	<u>Hosting:</u> EC2 <u>Operating Systems:</u> Amazon Linux 2023 Windows Server 2019 Windows Server 2016 <u>Networking:</u>

		AWS Network Security Groups AWS WAF <u>Databases:</u> Aurora Postgres SQL
GET	Platform tailored for organizations utilizing the CBORD card / cashless system to offer food ordering, virtual card payment, mobile access, and a loyalty system.	<u>Hosting Platform:</u> EC2 <u>Operating Systems:</u> Amazon Linux 2023 Windows Server <u>Networking:</u> AWS Network Security Groups AWS WAF <u>Databases:</u> Aurora Postgres SQL
MyPaymentsPlus	Online credit card and ACH payment service system that allows parents to make secure payments to their students MyPaymentsPlus account	<u>Hosting Platform:</u> EC2 <u>Operating Systems:</u> Windows Server 2019 Windows Server 2016 <u>Networking:</u> AWS Network Security Groups AWS WAF <u>Databases:</u> SQL Server

Software

Software consists of the programs and software that support the Online Transaction Processing System (i.e., OSs, middleware, and utilities). The list of software and ancillary software used to build, support, secure, maintain, and monitor the Online Transaction Processing System includes the following applications, as shown in the table below:

Production Application	Business Function
Active Directory	Identity and access management
Ansible	Automation tool for IT infrastructure automation and server management.
AWS RDS	Production data protection and storage and data backup and replication

Production Application	Business Function
AWS CloudFormation	Configuration management
AWS CloudWatch	Application and infrastructure monitoring
AWS Systems Manage (SSM)	Patch management for production systems
Bitbucket	Source code and software development management
Check MK	Infrastructure monitoring
CircleCI	Cloud-based CI/CD platform for streamlining development workflows
CrowdStrike Falcon and Rapid7 InsightVM	Security information and event management (SIEM), logging system, anti-virus, intrusion detection and prevention, and File Integrity Monitoring (FIM)
Datadog	Application and infrastructure monitoring
Navex	Awareness & Education
Jira Service Desk	Help desk, ticketing system
Okta	Identity and access management
OneTrust	Governance, Risk & Compliance
Intruder and Clone Systems	Vulnerability scanning
Terraform	Configuration management
Assured DataProtect	Corporate infrastructure backup and replication
Waves	Awareness & Education
AuditBoard	Governance, Risk, & Compliance

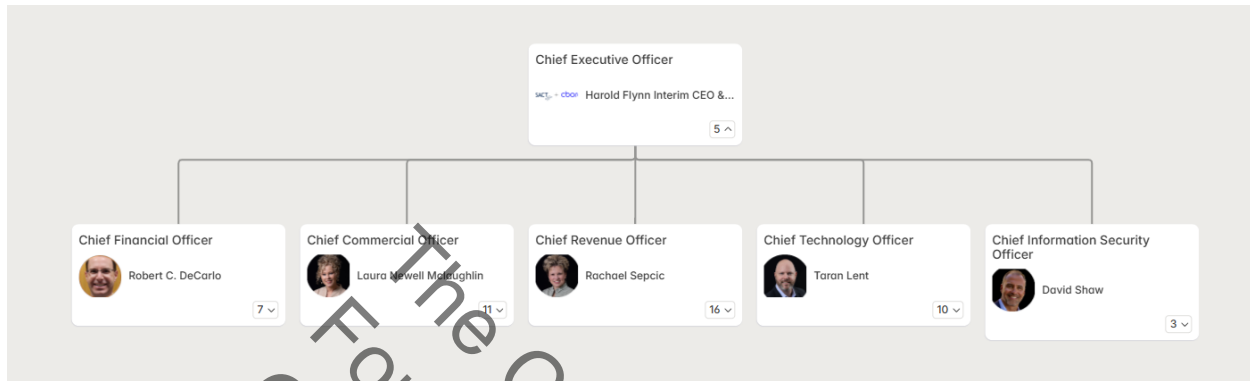
People

The company develops, manages, and secures the Online Transaction Processing System via separate departments. The responsibilities of these departments include:

- **Executive Management:** Responsible for overseeing company-wide activities, establishing and accomplishing goals, and managing objectives.
- **Development:** Responsible for the development, testing, integration, and maintenance of new code for the Online Transaction Processing Systems.
- **DevOps:** Responsible for managing access controls and the security of the production environment, as well as deploying, maintaining and monitoring the hosted systems and applications.

- **Product Management:** Responsible for overseeing the product life cycle, including adding new product functionality.
- **Human Resources (HR):** Responsible for onboarding new personnel, defining the roles and positions of new hires, performing background checks, and facilitating the employee termination process.

The CBORD Executive team organization structure is illustrated in the chart below.



Procedures

TRANSACTION PROCESSING

CBORD's NetMenu application consolidates information on food production, inventory, and menu planning, integrating accounting and point-of-sale systems. The system may also receive patient data for dietary restrictions to ensure patient safety.

CBORD's Odyssey Direct receives transaction information from various connected systems, such as door and card readers, where cardholders use their cards to validate credentials and can use funds in their accounts to make purchases. This system interfaces with customer point-of-sale terminals to handle transactions using the cards. The system can also integrate with other campus systems, such as housing, access control, and student information systems. Odyssey Direct is configured to support users' ability to receive alert emails and regular or ad-hoc transactional reports to ensure that transactions are processed correctly.

CBORD's GET allows users to view real-time balance information and transaction history, report a card lost or found, and make deposits using a credit card. Additional core features include food ordering, virtual card payment, mobile access, and a loyalty system. GET also supports integrating campus authentication systems and e-commerce merchant accounts for acceptance of credit card payments.

CBORD's MyPaymentsPlus provides multitude of paths for data to flow in a variety of formats for the merchant organization's reconciliation processes. Some processes involve automation and integrations, and others can be initiated by customers directly. Here are some examples of the various functionality with the system:

- Meal purchases are completed, and payment is sent to the point-of-sale terminal resulting in student balances being updated within the application. These transactions are communicated securely through encrypted connections.
- Fee, activity, and exam payments are acknowledged via reports available online or through instant, daily, or weekly roster notifications.
- Integration application programming interface (APIs) are available for users to integrate data in and out of the system, including fee import, fee payment export, and account system integrations.
- Multiple automated processes occur, including sending notifications, automated payments based on threshold, and processor feedback on already purchased transactions.

Most core processes, such as alerts, scheduled payments, reconciliation, and payment returns are logged and alerted.

The processing performed within these systems creates a data trail that can be analyzed and reported to identify discrepancies. System logic is coded into the system and generates on-screen alerts in the event that there are any issues when inputting or processing transactions. The systems can also produce reconciliation reports that allow for the review of transactions by users. Furthermore, edits that fail basic checks, such as entering non-numeric information or negative numbers when inappropriate, are automatically rejected and result in real-time alerts.

INFRASTRUCTURE MANAGEMENT

Information security policies and procedures are documented and define the information security rules and requirements for the service environment and are made available to employees via the corporate intranet. Roles and responsibilities are defined within security policies to establish accountability for the protection of information assets. Policy and procedure maintenance standards are in place that define requirements for the development and review of policies and procedures to ensure they remain current and aligned with the organization's strategic objectives and regulatory requirements. Annually, organizational policies and procedures are reviewed and updated to ensure that content is current and accurate.

An acceptable usage policy is in place that defines employee responsibilities and boundaries regarding the use of technology and information systems. A clean desk policy is in place that defines requirements for personnel to remove or securely store documents, devices, and sensitive materials when leaving their workstation. A teleworking policy is in place that defines requirements for secure remote work, including data protection, use of approved devices, and secure communication channels.

Information Security

User Registration and De-registration

Access control requests are initiated when a user's manager seeks to grant or revoke access via the organization's ticketing system. These requests are triggered by various events, such as the onboarding of a new employee, an employee's departure, a change in job roles, or adjustments to permissions and access rights. Notifications regarding these events are directed to the IT or DevOps teams, depending on the specific system for which access is requested or revoked. These notifications are dispatched by creating a ticket or sending an email notice to the relevant system team or owner.

The IT and DevOps teams undertake the responsibility of reviewing these access requests. Access is granted if the request aligns with the organization's access policies. Additional information is requested if required, or the request is denied if necessary.

Furthermore, as part of regular procedures, access rights are subject to quarterly review by the leadership of the IT and DevOps teams for their respective systems. Any inconsistencies or discrepancies discovered during these reviews are rectified in accordance with the access control policies established by CBORD.

When removing access due to an employee's termination, the IT team leverages the information provided within the ticket to determine which access rights need to be revoked. This may involve deactivating the user's Active Directory account and removing them from relevant security groups. Termination checklists are completed to track employee terminations, and access is revoked for employees within 24 hours of termination as part of the termination process.

Account Management and Access Control

CBORD subscribes to the principle of least privileges, meaning that users are granted the least possible privileges required to do their work. Temporary assignments may be made for short-term projects as long as access is revoked once the work is complete.

User accounts are unique to a person, and Single Sign-On (SSO) with Active Directory is used where possible to simplify account management. Administrative access to the SSO tool is restricted to personnel commensurate with their job role.

Password management policies and procedures are in place that define requirements for creating, handling, and configuring passwords to ensure the confidentiality and security of access to systems and data. Domain account settings are configured to enforce password length, complexity, expiry, history, and account lockout. A password management tool is in place to protect and store credentials to privileged accounts. Administrative access to the password management tool is restricted to personnel commensurate with their job role.

Multifactor Authentication (MFA) is also employed as an additional layer of security. Additionally, CBORD utilizes Group Policy Objects (GPO) as a central mechanism for enhancing its access control measures, allowing the enforcement of password restrictions, account lockout settings, and idle timeouts on domain-joined user workstations.

Access to in-scope applications requires a unique ID and password, which enables individual accountability and minimizes the risk of unauthorized access. Furthermore, password options are coded into the applications, allowing customers to define and set their password requirements, tailoring security protocols to their needs. Additionally, CBORD has incorporated role-based access control (RBAC) into the design of its applications, ensuring that users are granted permissions strictly based on their specific roles.

Network Segmentation

Network segmentation is in place between the hosted products in AWS, corporate-use AWS instances, and the corporate offices to prevent unauthorized access to sensitive data. Products are separated into their accounts on AWS, with explicit configuration required to allow communication. Administrative access to the AWS console is restricted to personnel commensurate with their job role.

Inventory Management

CBORD maintains a detailed inventory of information systems through security management tools. Assets are identified, inventoried, and classified. The IT and the DevOps teams monitor and maintain the inventory of assets for their respective systems. CBORD checks for completeness and accuracy of the inventory to ensure that it represents the production environment appropriately and has created and implemented processes to control the delivery and removal of information assets through a centralized ticketing system.

Systems Operations

Configuration Management

Technical standards and baselines have been established and communicated for the Online Transaction Processing System's deployments. These standards include baseline configurations for the virtual machines, virtual network devices, network architecture, and approved protocols and ports. The DevOps team regularly monitors the virtual network and machines for compliance with technical standards and potential malicious activities.

Further, system configuration and changes are monitored by AWS CloudWatch, which can report on issues. Instances are deployed with scripts to ensure consistency on critical infrastructure in production and the disaster recovery site on AWS.

System Monitoring and Vulnerability Management

System activity review policies and procedures are in place that define standards and processes for regularly monitoring and reviewing activities related to information systems. CBORD has implemented agent-based monitoring infrastructure and custom script-based monitoring within the environment to provide automated logging and alerting capabilities. The logging solutions are enabled on production systems. The monitoring system detects potential unauthorized activity and security events, such as the creation of unauthorized local users or unusual activity. The monitoring agents are responsible for monitoring a defined set of user and administrator events, aggregating log events, and sending the aggregated abnormal log information to a centralized log repository at regular intervals or in real time.

CBORD performs regular internal and external scans to identify vulnerabilities and assess the effectiveness of the patch management process. These scans are used to ensure compliance with baseline configuration templates, validate that relevant patches are installed, and identify vulnerabilities. The scanning reports are reviewed, and remediation efforts are conducted timely. The applicable security patches are applied as available or during a scheduled release to the environment based on the severity of the vulnerability. Patches are released in accordance with change and release management procedures, and emergency out-of-band security patches are expedited for a quicker release. In addition to regular vulnerability scanning activities, CBORD employs independent third parties to perform penetration testing annually.

Security groups are used and configured to prevent unauthorized access to the production environment. Web Application Firewalls (WAFs) are used and configured to prevent unauthorized access to the production environment.

Production systems are protected by host-based Intrusion Detection System (IDS) / Intrusion Prevention System (IPS). A FIM tool is used to notify system administrators of potential unauthorized changes to the production systems. Further, systems are protected by anti-virus software, which updates automatically, and scans hosted instances regularly. Corporate systems and workstations have anti-virus set to automatically update several times daily and monitor for malware activity on the machines in real time.

A mobile device policy is in place that defines requirements for the protection of mobile computing devices that connect to the organization's network and system assets. Technical policies are configured to restrict the use of USB drives and other portable storage media on end-user devices.

Log Management

Logging activities are tailored to the specific characteristics of each security event, employing a range of tools across numerous systems. These logs are monitored and assessed to ensure timely and effective resolution. In cases of major incidents, a protocol is in place to escalate the matter to Roper Technologies and its legal team, in accordance with the established Incident Response (IR) plan.

To ensure the continued effectiveness of the incident response program, regular testing is conducted, with the incident response plan undergoing evaluation at least annually. Access to administrate the log management tool is restricted to personnel commensurate with their job role.

Physical and Environmental Security

CBORD's Online Transaction Processing System is hosted within AWS. Physical access to the facilities and hardware hosting CBORD's systems is the responsibility of Azure. CBORD monitors the effectiveness of AWS' physical and environmental security controls via inspection of its Service Auditor report on an annual basis.

Change Management

Change control policies and procedures are in place that define requirements for the categorization, approval, and testing of changes to maintain system integrity and security. A source code repository is used to control access to source code. CBORD's software development practices adhere to the Software Development Lifecycle (SDLC) methodology, which incorporates security control specifications into the design and review processes. CBORD's ticketing system provides a structured framework that enables developers to manage their work within separate projects, distinct from DevOps. This separation allows for the planning, approval, or denial of code changes as required by designated team members, ensuring that related tasks are executed in accordance with the principle of segregation of duties (SOD).

Application changes are formally documented, tested, and approved prior to being implemented in the production environment. Following the completion of coding, the Quality Assurance (QA) team conducts testing and records their findings within the ticketing system. Access to deploy changes to production is restricted to personnel commensurate with their job function. Once a release has been tested and approved, the product team notifies DevOps, who then initiates deployment to a separate staging environment for further testing. This deployment is carried out using the provided installers and deployment scripts tailored to the specific application. User acceptance testing (UAT) is performed to confirm the successful deployment and normal operation of the system.

Upon successful UAT, the same validated scripts and installers are employed by DevOps to deploy the update to the production environment. The DevOps deployment team then conducts validation to ensure a smooth deployment, normal software operation, and the absence of alarms on any monitoring solutions.

Availability

Disaster Recovery Strategy

System capacity is measured and analysed using enterprise monitoring tools, which collect information about system utilization, overall performance, and subcomponent capacity. The system alerts administrators when thresholds are crossed so corrective action can be taken before availability is compromised. System data is replicated to the CBORD's Disaster Recovery (DR) site in an alternate AWS region at least daily. Depending on the application, this process may happen in near real-time. These backups can be enabled, and the DR site can be activated within hours.

Risks to the environment are primarily from malware, AWS outages, security issues, and harmful updates. These are mitigated in a multilevel risk assessment and management process that assigns severity based on the impact of a risk occurring combined with the likelihood of that happening.

CBORD upholds a primary Business Continuity and Disaster Recovery Plan (BCP), which serves as a guide for addressing disruptive events. Within this framework, the DevOps team maintains procedural documents that facilitate the recreation of production environments or the disaster recovery site and the seamless migration of data.

Data Replication

Production data is replicated to the DR site in AWS automatically and continuously. The business continuity plan (BCP) procedures define the virtual instances set up by automation scripts to enhance the security and speed of deployment. DR setup and migration are performed by the same infrastructure deployment scripts used to upgrade and deploy in production and are therefore tested at deployment. These procedures are formally tested at least annually to evaluate the current effectiveness of CBORD's DR plan.

Backups

An automated backup policy is defined in AWS to use Amazon's built-in snapshot capabilities of machines. By applying tags to virtual instances, devices are automatically backed up and retained based on the defined policy. Production systems are backed up via snapshot daily and are kept for seven days. Databases not on automatic multi-Availability Zone replication (which is near real time) are backed up at least daily to an alternate Availability Zone, and those backups are retained for a minimum of seven days. Administrators are notified in the event of data replication failures.

Corporate systems are also backed up daily, with retention settings configured to keep the backups for at least one week.

Data

Data Handling and Classification

A data classification policy is in place to help ensure that confidential data is properly secured and restricted to authorized personnel. Data is categorized into three distinct types as per the Data Classification policy: Non-Sensitive (inclusive of public or test data), Sensitive (comprising internal and proprietary CBORD information), and Private / Confidential (encompassing Personally Identifiable Information (PII), Protected Health Information (PHI), and client data). A PHI protection policy is in place to help safeguard covered and sensitive information from being disclosed to unauthorized users.

In this context, data encompasses transaction streams, files, data stores, tables, and output that CBORD uses or processes. Customers or end-users can define and manage the data they load into and store within the Online Transaction Processing System's production network through the API. Once this data is stored in the environment, it can be remotely accessed from customer systems via the Internet.

Encryption

An encryption policy is in place that defines requirements for the use of encryption protocols to ensure the protection of sensitive information. Private and confidential data is subject to encryption at rest and during transmission, which is strictly prohibited in non-production environments.

Secure data transmission protocols are used to encrypt confidential and sensitive data when transmitted over public networks. Data stores are configured to enforce encryption at rest, ensuring the confidentiality and security of the stored data.

Data Retention and Disposal

Data retention and disposal policies are in place that define requirements for the retention and secure disposal of confidential information and assets. Electronic media containing confidential information is purged or destroyed and certificates of destruction are issued for each device destroyed.

The Odyssey Direct application maintains backend accounts for patrons for cashless card systems and identity management. This includes PII, account balances, and linkage information to other systems that feed data to it. Reporting data includes, but is not limited to, the following:

- Account Balances
- Names
- Patron History
- Transaction Listing
- Plan Membership Summary
- Tender Totals
- Optional Custom Customer-Specific Data

The NetMenu application maintains food inventory, menus, recipes, and additional food service automation. The system links with other systems and may contain PII and Health Insurance Portability and Accountability Act (HIPAA) data to tailor menus to patrons with dietary restrictions. NetMenu interfaces to point-of-sale systems for automatic control. Reporting data includes, but is not limited to, the following:

- Names
- Facilities
- Units
- Vendors
- Protected Health Information (patient number, name, location, diagnosis information, and other related health data used in meal restriction planning)
- Recipe Information

GET is a centralized, cloud-based platform for organizations with a CBORD card / cashless system that wants to increase the service they provide to their patrons, expand patron usage of the cashless program, and drive user engagement, and revenue. GET provides an all-in-one experience students expect in an evolving mobile space through the CBORD platform.

- Account Balances
- Names
- Patron History
- Transaction Listing
- Plan Membership Summary
- Tender Totals
- Optional Custom Customer-Specific Data

RELEVANT ASPECTS OF CONTROL ENVIRONMENT, RISK ASSESSMENT, INFORMATION AND COMMUNICATIONS SYSTEMS, AND MONITORING

Control Environment

The control environment sets the tone of an organization, influencing the control consciousness of its people. It is the foundation for all other components of internal controls, providing discipline and structure. Aspects of CBORD's control environment that affect the services provided and / or the system of controls are identified in this section.

Integrity and Ethical Values

The effectiveness and strength of controls is inherently tied to the integrity and ethical values upheld by those responsible for their creation, oversight, and management. Within CBORD's control environment, integrity and ethical values hold a central role, influencing the development, implementation, and supervision of other control components.

CBORD's Management delivers consistent and periodic messages to its employees regarding the value of teamwork, collective versus individual success, the importance of customer service versus self-service, and that success for the organization and the individual will not occur as the result of any unethical or deceptive behavior.

To control this, employees are required to acknowledge that they read and agree to the code of conduct. They are also required to sign confidentiality agreements to protect company and customer data, and employees are subjected to a background check before starting work. At CBORD, managers appraise employee performance at least annually, and there is a documented sanctions policy to address performance issues or transgressions of the company's ethics and integrity policies.

Further, a formalized ethics and compliance policy is established, and an anonymous communication channel is in place for employees to report potential security issues or fraud concerns.

Board of Directors and Executive Management

CBORD's Management meets at least once quarterly to review business results and consult on significant business decisions, including risk, compliance, and internal control items. The company is solely owned by Roper Technologies, whose Board of Directors comprises a majority of independent members to encourage independent decision-making and mitigate conflicts of interest that may arise. The company has formal documentation in place regarding the oversight responsibilities of the parent company and the company relative to internal control.

Commitment to Competence

CBORD's management defines competence as the knowledge and skills necessary to accomplish tasks that define employees' roles and responsibilities. CBORD's commitment to competence includes management's consideration of the competence levels for particular jobs and how those levels translate into requisite skills and knowledge.

The Information Security Officer oversees the control environment and executes the company's strategy and other decisions agreed upon by executive management and the board of directors. The Information Security Officer reports administratively to the Vice President of Development and Technology. As part of the development of specific business objectives, the Information Security Officer updates the company's overall goals with the objectives of the business units and other functional areas.

Management's Philosophy and Operating Style

CBORD's management philosophy and operating style encompasses a broad range of characteristics including management's approach to taking and monitoring business risks, attitudes toward confidential information processing, and competent trained personnel.

Organizational Structure

CBORD's organizational structure provides the framework within which its activities for achieving entity-wide objectives are planned, executed, controlled, and monitored.

CBORD's management believes that establishing a relevant organizational structure includes considering key areas of authority and responsibility and appropriate lines of reporting. CBORD has developed an organizational structure suited to its needs. This organizational structure is based partly on its size and the nature of its activities.

Human Resource Policies and Practices

CBORD's HR policies and practices relate to employee hiring, training, evaluation, and disciplinary activities. Specific control activities CBORD has implemented in this area are described below.

- A new hire checklist is utilized to help ensure that components of the hiring process are consistently executed.
- Employee termination procedures have been established that guide the termination process.
- New hires are required to pass a background check and drug screening before starting employment.
- Upon hire and annually thereafter, employees complete mandatory Security Awareness Training, which covers basic information security practices and assists employees in avoiding phishing and malware, identifying insecure situations to report, and ensuring data is kept secure.
- Employees are reviewed at least annually, typically quarterly, by their supervisors to establish goals and expectations, and to compare past performance against previous goals and expectations.

If an employee violates the code of conduct and ethics policies or otherwise acts in a manner deemed contrary to the missions and objectives of the company, the employee is subject to sanctions, up to and including termination of employment.

Risk Assessment

Risk assessment is identifying and analyzing relevant risks that could prevent CBORD's management from achieving its operational compliance objectives. A risk management policy is in place that standardizes processes for the identification of risks and vulnerabilities to the confidentiality, integrity, and availability of sensitive information. Management formally assesses and manages risk that could affect the organization's ability to provide services to its customers at least annually. For any significant risks identified, Management is responsible for implementing appropriate measures to remediate or manage these risks. For risks that CBORD's management is unable to mitigate through compensating controls to an acceptable level, risk transfer is utilized through purchase of cyber security insurance.

Management has implemented a process whereby the likelihood and impact of various risks to the in-scope services have been assessed. Management broadly assigns risk levels to the identified risks according to the following three categories: Low, Medium, or High. Risks assessed at a level of "High" are inserted into the internal audit program. The internal audit program is focused solely on controls with a High-Risk level.

Upon completion of the audit, where possible, a mitigation plan is created and implemented to reduce the level of risk to an acceptable level as defined by management. Risks are mitigated through one of the following: Acceptance, Transfer, Avoidance, or Mitigation with Compensating controls. Management has identified control activities designed to mitigate the risks associated with the control objectives within scope. Additionally, management reviews the assessed risk levels on an ongoing basis or at least annually and documents the risk assessment in the annual risk program.

Management considers risks that can arise from both external and internal factors, including the following:

- External Factors
 - Technological developments
 - Changing customer needs or expectations
 - Competition that could alter marketing or service activities
 - New legislation and regulation that could force changes in policies and strategies
 - Natural catastrophes that could lead to changes in operations or information systems
 - Economic changes that could have an impact on management decisions
 - Third-party risk considerations
- Internal Factors
 - Significant changes in policies, processes, or personnel
 - Types of fraud
 - Fraud incentives and pressures for employees
 - Fraud opportunities
 - Employee attitudes and rationalizations for fraud
 - A disruption in information systems processing
 - The quality of personnel hired and methods of training utilized
 - Changes in management responsibilities

Information and Communication Systems

Information System

Information is necessary for CBORD to carry out internal control responsibilities to support the achievement of its objectives related to the Online Transaction Processing System. Management obtains or generates and uses relevant and quality information from internal and external sources to support internal control.

The following provides a summary of internal and external sources of information used in the Online Transaction Processing Systems:

- Monitoring application reports
- Change request tickets
- HR hiring and termination records
- Transaction confirmation files
- Regular self-assessments (performed by Roper Technologies)
- Vulnerability scans
- Log management tools
- File integrity monitoring tools

Communication System

Communication takes such forms as policy manuals and memoranda. Communications also can be made electronically, verbally, and through the actions of management. Furthermore, policies are available to authorized users via the company intranet site.

CBORD has implemented various communication methods to help ensure that employees understand their individual roles and responsibilities and that significant events are communicated. These methods include orientation for new employees, training for employees, intranet alerts, and email messages to communicate time-sensitive information. Employees are encouraged to communicate upward to their lead / mentor, supervisor / manager, or Senior / Executive Management. CBORD also provides anonymous communication channels for reporting issues through the Roper Technology Ethics and Compliance Line, and a third-party hosted portal through Ethics Point. CBORD also maintains an intranet site that hosts resources, such as network diagrams, policies, procedures, and standards, for communicating and understanding system and environment boundaries.

CBORD has also implemented various methods of communication to help provide assurance that customers understand the roles and responsibilities in processing their transactions and communication of significant events. These methods include the use of email messages and the company's customer contact line to communicate time-sensitive information. Customers may also use the company's support portals, which contain a variety of information including knowledgebase articles, technical guides, Frequently Asked Questions (FAQ), release notes, and the status of current support cases. From the portal, a customer may report new system issues, incidents, concerns, questions, or failures directly to the CBORD ticketing systems. Customers can also reference system and product descriptions through their knowledgebase portal and may opt-in to receive email notifications regarding critical changes to the applications and systems.

If incidents are communicated, personnel follow the documented incident response plan. For example, if a change in procedure is required, the product manager is advised of the change. Formal procedure changes are distributed to management before they are incorporated into the policy and distributed to relevant parties. Incidents are documented within the ticketing system and tracked by management until resolved.

The Information Security Team subscribes to industry security bulletins and email alerts to monitor the impact of emerging technologies and other factors that influence the security posture of the company.

Monitoring

On-Going Monitoring

External and internal vulnerability scanning is performed quarterly, and penetration testing is conducted annually, while the endpoint protection system performs such scans near-continuously and locally on the machines themselves. Detected items are classified by the scanning product's classification and management discretion. These are then put into work for remediation based on their determined severity and tracked in the responding team's ticketing system.

Management has implemented a self-assessment program to evaluate the performance of specific control activities and processes over time and to confirm that the in-scope controls are consistently applied as designed, including whether manual controls are applied by individuals with the appropriate competence and authority. As a result of management's risk analysis process, control activities within scope are assigned a risk level associated with the assessed level of risk it is intended to mitigate. Controls that serve to mitigate multiple risks are assigned the highest level of assessed risk among the pertinent risks.

Management has determined that risk assignments or categories require structured inquiry, observation, inspection, or sample testing, or a combination of the aforementioned. These requirements are determined based on the assigned risk level; the nature of the control, whether automated or manual; and the frequency of application (e.g., constant, daily, weekly, quarterly).

Vendor and Sub-Service Organization Monitoring

To maintain the security of customer data, contracts are signed with vendors as part of the onboarding process. Specifically, those who will handle sensitive information or have information sharing agreements established by CBORD. Additionally, management also performs annual risk assessments on high-risk vendors to proactively identify and mitigate third-party risks that could adversely impact CBORD's business operations.

CBORD's management obtains and reviews the annual Service Auditor's reports for AWS and Okta to monitor and evaluate the adequacy and effectiveness of controls in place at the sub-service organizations. In addition, application and network monitoring tools are used to ensure service commitments of AWS and Okta are achieved. Incidents are communicated to AWS and Okta support, as needed.

CATEGORIES, CRITERIA, AND RELATED CONTROLS

The categories, criteria, and related controls are included in Section 4 of this report, “Categories, Criteria, Related Controls and Tests of Operating Effectiveness”, to eliminate the redundancy that would result from listing them in this section and repeating them in Section 4. Although the criteria and related controls are included in Section 4, they are, nevertheless, an integral part of the organization's description of controls.

The CBORD Group Inc
For AWS
Confidential

COMPLEMENTARY CONTROL CONSIDERATIONS

CBORD's policies and procedures over its Online Transaction Processing system cover only a portion of the overall internal control for each user entity. It is not feasible for CBORD's service commitments and systems requirements related to the Online Transaction Processing system to be solely achieved by CBORD. CBORD's control policies and procedures were designed with the assumption that certain controls would be in place and in operation at the sub-service organization and user entities. Sub-service organization controls and user entity internal controls must be evaluated, taking into consideration CBORD's controls and their own internal controls. CBORD's management does not make any representations regarding responsibility related to or provide any assurance regarding any such internal control or regulatory requirements for which the client must assess or comply.

This section describes some of the control considerations for the sub-service organization and user entities, or "complementary controls", which should be in operation at the sub-service organization and user entities to complement the controls at the service organization. User auditors / user entities should determine whether the sub-service organization and user entities have established controls to ensure that the criteria within this report are met. The "complementary controls" presented below should not be regarded as a comprehensive list of all controls that should be employed by the sub-service organization or user entities.

Complementary User Entity Controls

1. User entities are responsible for ensuring the system is set up and maintained with parameters that are configured to meet their unique transaction processing requirements.
2. User entities are responsible for performing reconciliations and reviews of their reports to ensure the completeness, timeliness, and accuracy of the information within the system.
3. User entities are responsible for reporting material changes to their overall control environment that may adversely affect services being performed by CBORD according to contractually specified time frames.
4. User entities are responsible for providing reasonable assurance that CBORD is notified of changes in user entity vendor security requirements and the authorized users list.

Complementary Sub-Service Organization Controls

1. The sub-service organization is responsible for implementing physical security controls to ensure access to facilities is limited to authorized personnel and that information systems are protected from unauthorized access, damage, and interference.
2. The sub-service organization is responsible for having proper logical security controls in place to ensure the security of systems and data.
3. The sub-service organization is responsible for notifying CBORD management of any actual or suspected security incidents or breaches in a timely manner.
4. The sub-service organization is responsible for notifying CBORD personnel in a timely manner when changes are made to technical or administrative controls that may impact CBORD's system.

SECTION 4:

**CATEGORIES, CRITERIA, CONTROL DESCRIPTIONS, RELATED
CONTROLS AND TESTS OF OPERATING EFFECTIVENESS**

INFORMATION PROVIDED BY THE SERVICE AUDITOR

Introduction

This report is intended to provide user entities, prospective user entities, independent auditors and practitioners providing services to such user entities, and regulators who have sufficient knowledge and understanding with information about controls that may affect the Online Transaction Processing system provided by CBORD and to provide information about the operating effectiveness of controls that were tested.

The scope of our testing of CBORD's controls was limited to the categories, criteria, and the related controls specified by CBORD's management and contained within Section 4 of this report, which management believes to be the relevant key controls for the categories and criteria included in the scope of this report. Our review was not extended to controls in place at any user entities, sub-service organization, or any other third-party vendors.

The examination was performed in accordance with the American Institute of Certified Public Accountants (AICPA) Statement on Standards for Attestation Engagements No. 21 '*Direct Examination Engagements*', specifically AT-C Section 105, '*Concepts Common to All Attestation Engagements*' and AT-C Section 205, '*Assertion – Based Examination Engagements*.' It is each interested party's responsibility to evaluate this information in relation to controls in place at user entities and sub-service organization (if applicable) to obtain an overall understanding of internal control and to assess control risk. Controls in place at user entities, sub-service organization (if applicable), and CBORD must be evaluated together. A general, but not inclusive, listing of control considerations is provided in Section 3, "Complementary Control Considerations." If an effectively operating user entity or sub-service organization (if applicable) internal control is not in place, the controls at CBORD may not sufficiently compensate for the deficiency.

Tests of Operating Effectiveness

Our tests of the operating effectiveness of the controls specified by CBORD's management included such tests as we considered necessary in the circumstances to obtain reasonable, but not absolute, assurance that the controls operated in a manner that achieved the specified criteria during the period from August 1, 2024 to July 31, 2025. In selecting particular tests of the operating effectiveness of controls we considered 1) the nature of the controls being tested; 2) the types and completeness of available evidential matter; 3) the nature of the criteria to be achieved; 4) the assessed level of control risk; 5) the expected efficiency and effectiveness of the test; and 6) the testing of other controls relevant to the criteria.

Testing exceptions, if any, and information about specific tests of the operating effectiveness performed that may be relevant to the interpretation of testing results by user entities, prospective user entities, independent auditors and practitioners providing services to such user entities, and regulators who have sufficient knowledge and understanding for the controls specified to achieve the criteria are presented in this section under the column heading "Results of Testing." The concept of materiality is not applied when reporting the results of the tests of controls for which exceptions have been identified because the independent service auditor does not have the ability to determine whether an exception will be relevant to a particular user entity. Consequently, Hiestand, Brand, Loughran, P.A. reports all exceptions. Exceptions identified herein are not necessarily considered significant deficiencies or material weaknesses in the total system of internal controls of CBORD, as this determination can only be made after consideration of controls in place at user entities. Control considerations that should be exercised by CBORD's clients to complement the controls of CBORD to attain the criteria are presented in relation to the nature of services being audited and the controls specified by CBORD management.

Types of Tests Performed

The table below describes the nature of our audit procedures and tests performed to evaluate the operational effectiveness of the controls detailed in the matrices that follow:

Test Types	Description of Tests
Inquiry	Inquired of appropriate personnel seeking relevant information or representation to obtain the following information about the control: ➤ Knowledge and additional information regarding the policy or procedure; and ➤ Corroborating evidence of the policy or procedure.
Inspection	Inspected documents and records indicating performance of the control. This includes, but is not limited to, the following: ➤ Examination / Inspection of source documentation and authorizations to verify transactions processed; ➤ Examination / Inspection of documents or records for evidence of performance, such as existence of initials or signatures; ➤ Examination / Inspection of systems documentation, configurations and settings; and ➤ Examination / Inspection of procedural documentation such as operations manuals, flow charts and job descriptions.
Observation	Observed the implementation, application or existence of specific controls as represented
Re-performance	Re-performed the control to verify the design and / or operation of the control activity as performed

Procedures for Assessing Completeness and Accuracy of IPE

For tests of controls requiring the use of Information Provided by the Entity ("IPE") (e.g., controls requiring system generated populations for sample-based testing), Hiestand, Brand, Loughran, P.A. performed a combination of the following procedures, where possible, based on the nature of the IPE to address the completeness, accuracy, and data integrity of the data or reports used: (1) inspected the source of the IPE, (2) inspected the query, script, or parameters used to generate the IPE, (3) tied data between the IPE and the source, and / or (4) inspected the IPE for anomalous gaps in sequence or timing to determine the data is complete, accurate, and maintained its integrity. In addition to the above procedures, for tests of controls requiring management's use of IPE in the execution of the controls (e.g., periodic reviews of user access listings), the independent service auditor inspected management's procedures to assess the validity of the IPE source and the completeness, accuracy, and integrity of the data or reports.

Sampling Methodology

The table below describes the sampling methodology utilized in our testing to evaluate the operational effectiveness of the controls detailed in the matrices that follow:

Type of Control and Frequency	Minimum Number of Items to Test (Period of Review Six Months or Less)	Minimum Number of Items to Test (Period of Review More than Six Months)
Manual control, many times per day	At least 25	At least 25
Manual control, daily (Note 1)	At least 25	At least 25
Manual control, weekly	At least 5	At least 10
Manual control, monthly	At least 3	At least 4
Manual control, quarterly	At least 2	At least 2
Manual control, annually	Test annually	Test annually
Application controls	Test one operation of each relevant aspect of each application control if supported by effective IT general controls; otherwise test at least 15	Test one operation of each application control if supported by effective IT general controls; otherwise test at least 25
IT general controls	Follow guidance above for manual and automated aspects of IT general controls	Follow guidance above for manual and automated aspects of IT general controls

Notes: 1.) Some controls might be performed frequently, but less than daily. For such controls, the sample size should be interpolated using the above guidance. Generally, for controls where the number of occurrences ranges from 50 to 250 during the year, our minimum sample size using the above table should be approximately 10% of the number of occurrences.

CATEGORIES, CRITERIA, AND RELATED CONTROLS

Security (Common Criteria to All Categories)

Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to meet its objectives.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
Control Environment			
CC1.1 - COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.			
CTL-001	Policies and procedures are maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-002	A formal policy is in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	Inquired of the Director of Information Security to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
		Inspected the Code of Conduct and corporate intranet to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
CTL-003	Upon hire, employees are required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage.	Inquired of the Director of Information Security to verify that employees were required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage upon hire.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the code of conduct acknowledgement for a sample of employees onboarded during the examination period to verify that employees were required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage upon hire.	No exceptions noted.
CTL-004	Upon hire, employees are required to sign a confidentiality agreement that prohibits the disclosure of sensitive information to unauthorized parties.	Inquired of the Director of Information Security to verify that employees were required to sign a confidentiality agreement that prohibits the disclosure of sensitive information to unauthorized parties upon hire.	No exceptions noted.
		Inspected the signed confidentiality agreements for a sample of employees onboarded during the examination period to verify that employees were required to sign a confidentiality agreement that prohibits the disclosure of sensitive information to unauthorized parties upon hire.	No exceptions noted.
CTL-005	A sanctioning policy is in place that informs personnel of disciplinary action, up to and including termination, for violation of security policies.	Inquired of the Director of Information Security to verify that a sanctioning policy was in place that informs personnel of disciplinary action, up to and including termination, for violation of security policies.	No exceptions noted.
		Inspected the Code of Conduct to verify that a sanctioning policy was in place that informs personnel of disciplinary action, up to and including termination, for violation of security policies.	No exceptions noted.
CTL-006	Agreements are executed with vendors and service providers as a component of the onboarding process that include the defined terms and conditions and the responsibilities for parties with access to confidential information.	Inquired of the Director of Information Security to verify that agreements were executed with vendors and service providers as a component of the onboarding process that include the defined terms and conditions and the responsibilities for parties with access to confidential information.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC1.2 - COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.			
CTL-007	Quarterly, the Executive Team meets to discuss business objectives and establish company direction.	Inquired of the Director of Information Security to verify that the Executive Team meets on a quarterly basis to discuss business objectives and establish company direction.	No exceptions noted.
		Inspected the executive leadership team meeting agendas for a sample of quarters to verify that the Executive Team meets on a quarterly basis to discuss business objectives and establish company direction.	No exceptions noted.
CTL-008	The compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	Inquired of the Director of Information Security to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
		Inspected the most recent risk assessment results to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
CTL-009	Quarterly, the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy and reports directly to the board of directors' audit committee.	Inquired of the Director of Information Security to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.
		Inspected the compliance committee meeting agendas for a sample of quarters to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-010	Roles and responsibilities are defined within security policies to establish accountability for the protection of information assets.	Inquired of the Director of Information Security to verify that roles and responsibilities were defined within security policies to establish accountability for the protection of information assets.	No exceptions noted.
		Inspected the policies and procedures to verify that roles and responsibilities were defined within security policies to establish accountability for the protection of information assets.	No exceptions noted.
CC1.3 - COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.			
CTL-001	Policies and procedures are maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-008	The compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	Inquired of the Director of Information Security to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
		Inspected the most recent risk assessment results to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-009	Quarterly, the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy and reports directly to the board of directors' audit committee.	Inquired of the Director of Information Security to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.
		Inspected the compliance committee meeting agendas for a sample of quarters to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.
CTL-010	Roles and responsibilities are defined within security policies to establish accountability for the protection of information assets.	Inquired of the Director of Information Security to verify that roles and responsibilities were defined within security policies to establish accountability for the protection of information assets.	No exceptions noted.
		Inspected the policies and procedures to verify that roles and responsibilities were defined within security policies to establish accountability for the protection of information assets.	No exceptions noted.
CTL-011	Formal job descriptions are in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	Inquired of the Director of Information Security to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
		Inspected the relevant job descriptions to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
CTL-012	An organizational chart that defines departmental structure and reporting lines according to key areas of authority and responsibility is available to personnel via the corporate intranet.	Inquired of the Director of Information Security to verify that an organizational chart that defines departmental structure and reporting lines according to key areas of authority and responsibility was available to personnel via the corporate intranet.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the organizational chart to verify that an organizational chart that defines departmental structure and reporting lines according to key areas of authority and responsibility was available to personnel via the corporate intranet.	No exceptions noted.
CC1.4 - COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.			
CTL-003	Upon hire, employees are required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage.	Inquired of the Director of Information Security to verify that employees were required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage upon hire.	No exceptions noted.
		Inspected the code of conduct acknowledgement for a sample of employees onboarded during the examination period to verify that employees were required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage upon hire.	No exceptions noted.
CTL-011	Formal job descriptions are in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	Inquired of the Director of Information Security to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
		Inspected the relevant job descriptions to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
CTL-013	Background screenings are performed for employment candidates as a component of the onboarding process.	Inquired of the Director of Information Security to verify that background screenings were performed for employment candidates as a component of the onboarding process.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the background screenings for a sample of employees onboarded during the examination period to verify that background screenings were performed for employment candidates as a component of the onboarding process.	No exceptions noted.
CTL-014	Upon hire, employees are required to complete security awareness training as a component of the onboarding process.	Inquired of the Director of Information Security to verify that employees were required to complete security awareness training upon hire as a component of the onboarding process.	No exceptions noted.
		Inspected the completed security awareness training for a sample of employees onboarded during the examination period to verify that employees were required to complete security awareness training upon hire as a component of the onboarding process.	No exceptions noted.
CTL-015	Annually, employees are required to complete security awareness training.	Inquired of the Director of Information Security to verify that employees were required to complete security awareness training on an annual basis.	No exceptions noted.
		Inspected the completed security awareness training for a sample of current employees to verify that employees were required to complete security awareness training within the past 12 months.	Exceptions noted. It was noted for four of 25 tenured employees sampled for testing that security awareness training was not completed within the past 12 months.
CTL-016	Annually, performance reviews are performed to ensure ongoing employee development and competency.	Inquired of the Director of Information Security to verify that performance reviews were performed on an annual basis to ensure ongoing employee development and competency.	No exceptions noted.
		Inspected the completed performance reviews for a sample of current employees to verify that performance reviews were performed within the past 12 months to ensure ongoing employee development and competency.	Exceptions noted. It was noted for five of 25 tenured employees sampled for testing that a performance review was not performed within the past 12 months.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-029	Quarterly, internal phishing campaigns are performed to test user awareness of social engineering attacks.	Inquired of the Director of Information Security to verify that internal phishing campaigns were performed on a quarterly basis to test user awareness of social engineering attacks.	No exceptions noted.
		Inspected the internal phishing campaigns for a sample of quarters to verify that internal phishing campaigns were performed on a quarterly basis to test user awareness of social engineering attacks.	No exceptions noted.
CC1.5 - COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.			
CTL-001	Policies and procedures are maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-002	A formal policy is in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	Inquired of the Director of Information Security to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
		Inspected the Code of Conduct and corporate intranet to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-003	Upon hire, employees are required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage.	Inquired of the Director of Information Security to verify that employees were required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage upon hire.	No exceptions noted.
		Inspected the code of conduct acknowledgement for a sample of employees onboarded during the examination period to verify that employees were required to read and acknowledge the code of conduct describing their responsibilities and expected behavior regarding the protection of data and information system usage upon hire.	No exceptions noted.
CTL-005	A sanctioning policy is in place that informs personnel of disciplinary action, up to and including termination, for violation of security policies.	Inquired of the Director of Information Security to verify that a sanctioning policy was in place that informs personnel of disciplinary action, up to and including termination, for violation of security policies.	No exceptions noted.
		Inspected the Code of Conduct to verify that a sanctioning policy was in place that informs personnel of disciplinary action, up to and including termination, for violation of security policies.	No exceptions noted.
CTL-011	Formal job descriptions are in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	Inquired of the Director of Information Security to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
		Inspected the relevant job descriptions to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
CTL-013	Background screenings are performed for employment candidates as a component of the onboarding process.	Inquired of the Director of Information Security to verify that background screenings were performed for employment candidates as a component of the onboarding process.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the background screenings for a sample of employees onboarded during the examination period to verify that background screenings were performed for employment candidates as a component of the onboarding process.	No exceptions noted.
CTL-014	Upon hire, employees are required to complete security awareness training as a component of the onboarding process.	Inquired of the Director of Information Security to verify that employees were required to complete security awareness training upon hire as a component of the onboarding process.	No exceptions noted.
		Inspected the completed security awareness training for a sample of employees onboarded during the examination period to verify that employees were required to complete security awareness training upon hire as a component of the onboarding process.	No exceptions noted.
CTL-015	Annually, employees are required to complete security awareness training.	Inquired of the Director of Information Security to verify that employees were required to complete security awareness training on an annual basis.	No exceptions noted.
		Inspected the completed security awareness training for a sample of current employees to verify that employees were required to complete security awareness training within the past 12 months.	Exceptions noted. It was noted for four of 25 tenured employees sampled for testing that security awareness training was not completed within the past 12 months.
CTL-016	Annually, performance reviews are performed to ensure ongoing employee development and competency.	Inquired of the Director of Information Security to verify that performance reviews were performed on an annual basis to ensure ongoing employee development and competency.	No exceptions noted.
		Inspected the completed performance reviews for a sample of current employees to verify that performance reviews were performed within the past 12 months to ensure ongoing employee development and competency.	Exceptions noted. It was noted for five of 25 tenured employees sampled for testing that a performance review was not performed within the past 12 months.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-029	Quarterly, internal phishing campaigns are performed to test user awareness of social engineering attacks.	Inquired of the Director of Information Security to verify that internal phishing campaigns were performed on a quarterly basis to test user awareness of social engineering attacks.	No exceptions noted.
		Inspected the internal phishing campaigns for a sample of quarters to verify that internal phishing campaigns were performed on a quarterly basis to test user awareness of social engineering attacks.	No exceptions noted.
Communication and Information			
CC2.1 - COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.			
CTL-001	Policies and procedures are maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-002	A formal policy is in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	Inquired of the Director of Information Security to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
		Inspected the Code of Conduct and corporate intranet to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-017	Information security policies and procedures are documented and define the information security rules and requirements for the service environment.	Inquired of the Director of Information Security to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
		Inspected the System & Information Integrity policy and procedures to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
CTL-023	Quarterly, network vulnerability scans are performed to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans are remediated as determined by management review.	Inquired of the Director of Information Security to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
		Inspected the network vulnerability scans for a sample of quarters to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
CTL-024	Annually, a penetration test is performed to identify potential system security vulnerabilities. Vulnerabilities identified during the penetration test are remediated as determined by management review.	Inquired of the Director of Information Security to verify that a penetration test was performed to identify potential system security vulnerabilities on an annual basis. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the penetration test report and management review to verify that a penetration test was performed to identify potential system security vulnerabilities within the past 12 months. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
CTL-025	File integrity monitoring software is installed on systems to monitor and log changes to critical system or configuration files.	Inquired of the Director of Information Security to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
		Inspected the file integrity monitoring software to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
CC2.2 - COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.			
CTL-001	Policies and procedures are maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to provide personnel with guidance on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-010	Roles and responsibilities are defined within security policies to establish accountability for the protection of information assets.	Inquired of the Director of Information Security to verify that roles and responsibilities were defined within security policies to establish accountability for the protection of information assets.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the policies and procedures to verify that roles and responsibilities were defined within security policies to establish accountability for the protection of information assets.	No exceptions noted.
CTL-011	Formal job descriptions are in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	Inquired of the Director of Information Security to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
		Inspected the relevant job descriptions to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
CTL-014	Upon hire, employees are required to complete security awareness training as a component of the onboarding process.	Inquired of the Director of Information Security to verify that employees were required to complete security awareness training upon hire as a component of the onboarding process.	No exceptions noted.
		Inspected the completed security awareness training for a sample of employees onboarded during the examination period to verify that employees were required to complete security awareness training upon hire as a component of the onboarding process.	No exceptions noted.
CTL-015	Annually, employees are required to complete security awareness training.	Inquired of the Director of Information Security to verify that employees were required to complete security awareness training on an annual basis.	No exceptions noted.
		Inspected the completed security awareness training for a sample of current employees to verify that employees were required to complete security awareness training within the past 12 months.	Exceptions noted. It was noted for four of 25 tenured employees sampled for testing that security awareness training was not completed within the past 12 months.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-017	Information security policies and procedures are documented and define the information security rules and requirements for the service environment.	Inquired of the Director of Information Security to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
		Inspected the System & Information Integrity policy and procedures to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
CTL-018	Annually, control self-assessments are performed by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity are in place and operating effectively. Corrective actions are taken based on relevant findings of the annual control self-assessment and tracked to resolution.	Inquired of the Director of Information Security to verify that control self-assessments were performed by management on an annual basis to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
		Inspected the cyber self-assessment results and corrective action plan tracking tool to verify that control self-assessments were performed within the past 12 months by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
CTL-026	Security incident response policies and procedures are documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	Inquired of the Director of Information Security to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the incident response procedure policy and procedures to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
CTL-027	An incident response plan is in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP is reviewed and approved at least annually.	Inquired of the Director of Information Security to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
		Inspected the Incident Response Plan to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
CTL-029	Quarterly, internal phishing campaigns are performed to test user awareness of social engineering attacks.	Inquired of the Director of Information Security to verify that internal phishing campaigns were performed on a quarterly basis to test user awareness of social engineering attacks.	No exceptions noted.
		Inspected the internal phishing campaigns for a sample of quarters to verify that internal phishing campaigns were performed on a quarterly basis to test user awareness of social engineering attacks.	No exceptions noted.
CC2.3 - COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.			
CTL-006	Agreements are executed with vendors and service providers as a component of the onboarding process that include the defined terms and conditions and the responsibilities for parties with access to confidential information.	Inquired of the Director of Information Security to verify that agreements were executed with vendors and service providers as a component of the onboarding process that include the defined terms and conditions and the responsibilities for parties with access to confidential information.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-030	A description of the services is documented and communicated to internal and external users via the company website.	Inquired of the Director of Information Security to verify that a description of the services was documented and communicated to internal and external users via the company website.	No exceptions noted.
		Inspected the description of services on the company website to verify that a description of the services was documented and communicated to internal and external users via the company website.	No exceptions noted.
CTL-031	The terms of use and privacy statement are available via the company website.	Inquired of the Director of Information Security to verify that the terms of use and privacy statement were available via the company website.	No exceptions noted.
		Inspected the terms of use and privacy statement on the company website to verify that the terms of use and privacy statement were available via the company website.	No exceptions noted.
CTL-032	Online SLAs communicate commitments to customers.	Inquired of the Director of Information Security to verify that online SLAs communicate commitments to customers.	No exceptions noted.
		Inspected the service commitment communicated to customers to verify that online SLAs communicate commitments to customers.	No exceptions noted.
CTL-034	An external-facing support system is in place that allows clients to report system information on failures, incidents, concerns, and other complaints to the appropriate personnel.	Inquired of the Director of Information Security to verify that an external-facing support system was in place that allows clients to report system information on failures, incidents, concerns, and other complaints to the appropriate personnel.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the support system allowing clients to report on system information to verify that an external-facing support system was in place that allows clients to report system information on failures, incidents, concerns, and other complaints to the appropriate personnel.	No exceptions noted.
CTL-035	Agreements are executed with clients as a component of the onboarding process that define the in-scope service commitments: security, availability, confidentiality, and privacy.	Inquired of the Director of Information Security to verify that agreements were executed with clients as a component of the onboarding process that define the in-scope service commitments: security, availability, confidentiality, and privacy.	No exceptions noted.
		Inspected the executed agreements for a sample of clients onboarded during the examination period to verify that agreements were executed with clients as a component of the onboarding process that define the in-scope service commitments: security, availability, confidentiality, and privacy.	No exceptions noted.
CTL-036	Customers are notified of critical changes that may affect system processing.	Inquired of the Director of Information Security to verify that customers were notified of critical changes that may affect system processing.	No exceptions noted.
		Inspected the scheduled maintenance page to verify that customers were notified of critical changes that may affect system processing.	No exceptions noted.
CTL-037	Incidents related to security are logged, tracked, evaluated, and communicated to affected parties by management until remediation.	Inquired of the Director of Information Security to verify that incidents related to security were logged, tracked, evaluated, and communicated to affected parties by management until remediation.	No exceptions noted.
		Inspected the incident logs for a sample of incidents during the examination period to verify that incidents related to security were logged, tracked, evaluated, and communicated to affected parties by management until remediation.	No exceptions noted.
Risk Assessment			

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC3.1 - COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.			
CTL-038	A risk management policy is in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	Inquired of the Director of Information Security to verify that a risk management policy was in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	No exceptions noted.
		Inspected the Risk Assessment Policy to verify that a risk management policy was in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	No exceptions noted.
CTL-039	Annually, management performs a risk assessment that includes identifying, assessing, and mitigating the risks associated with threats that may impair management's ability to meet business objectives.	Inquired of the Director of Information Security to verify that management performs a risk assessment on an annual basis that includes identifying, assessing, and mitigating the risks associated with threats that may impair management's ability to meet business objectives.	No exceptions noted.
		Inspected the recent risk assessment results to verify that management performed a risk assessment within the past 12 months that includes identifying, assessing, and mitigating the risks associated with threats that may impair management's ability to meet business objectives.	No exceptions noted.
CTL-040	Business objectives are specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	Inquired of the Director of Information Security to verify that business objectives were specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	No exceptions noted.
		Inspected the annual risk assessment to verify that business objectives were specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-041	An inventory list of physical assets is maintained to track and log mobile devices and their assigned owners.	Inquired of the Director of Information Security to verify that an inventory list of physical assets was maintained to track and log mobile devices and their assigned owners.	No exceptions noted.
		Inspected the asset inventory to verify that an inventory list of physical assets was maintained to track and log mobile devices and their assigned owners.	No exceptions noted.
CC3.2 - COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.			
CTL-039	Annually, management performs a risk assessment that includes identifying, assessing, and mitigating the risks associated with threats that may impair management's ability to meet business objectives.	Inquired of the Director of Information Security to verify that management performs a risk assessment on an annual basis that includes identifying, assessing, and mitigating the risks associated with threats that may impair management's ability to meet business objectives.	No exceptions noted.
		Inspected the recent risk assessment results to verify that management performed a risk assessment within the past 12 months that includes identifying, assessing, and mitigating the risks associated with threats that may impair management's ability to meet business objectives.	No exceptions noted.
CTL-040	Business objectives are specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	Inquired of the Director of Information Security to verify that business objectives were specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	No exceptions noted.
		Inspected the annual risk assessment to verify that business objectives were specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-041	An inventory list of physical assets is maintained to track and log mobile devices and their assigned owners.	Inquired of the Director of Information Security to verify that an inventory list of physical assets was maintained to track and log mobile devices and their assigned owners.	No exceptions noted.
		Inspected the asset inventory to verify that an inventory list of physical assets was maintained to track and log mobile devices and their assigned owners.	No exceptions noted.
CC3.3 - COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.			
CTL-002	A formal policy is in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	Inquired of the Director of Information Security to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
		Inspected the Code of Conduct and corporate intranet to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
CTL-042	The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inquired of the Director of Information Security to verify that the risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	No exceptions noted.
		Inspected the risk assessment considerations to verify that the risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	No exceptions noted.
CTL-043	A fraud reporting hotline is in place for employees to anonymously report unethical and illegal activities and issues of non-compliance with company policies.	Inquired of the Director of Information Security to verify that a fraud reporting hotline was in place for employees to anonymously report unethical and illegal activities and issues of non-compliance with company policies.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the reporting hotline in the company portal to verify that a fraud reporting hotline was in place for employees to anonymously report unethical and illegal activities and issues of non-compliance with company policies.	No exceptions noted.
CTL-044	The organization retains legal counsel to provide guidance on legal matters affecting services.	Inquired of the Director of Information Security to verify that the organization retains legal counsel to provide guidance on legal matters affecting services.	No exceptions noted.
		Inspected the legal services provided to the organization to verify that the organization retains legal counsel to provide guidance on legal matters affecting services.	No exceptions noted.
CC3.4 - COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.			
CTL-008	The compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	Inquired of the Director of Information Security to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
		Inspected the most recent risk assessment results to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
CTL-018	Annually, control self-assessments are performed by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity are in place and operating effectively. Corrective actions are taken based on relevant findings of the annual control self-assessment and tracked to resolution.	Inquired of the Director of Information Security to verify that control self-assessments were performed by management on an annual basis to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the cyber self-assessment results and corrective action plan tracking tool to verify that control self-assessments were performed within the past 12 months by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
CTL-019	The security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	Inquired of the Director of Information Security to verify that the security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	No exceptions noted.
		Inspected the subscriptions by the security owners to industry security bulletins to verify that the security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	No exceptions noted.
CTL-045	Annually, management performs a risk assessment that includes identifying, assessing, and mitigating the risks associated with changes that could impact the internal control environment.	Inquired of the Director of Information Security to verify that management performed a risk assessment on an annual basis that includes identifying, assessing, and mitigating the risks associated with changes that could impact the internal control environment.	No exceptions noted.
		Inspected the risk assessment to verify that management performed a risk assessment within the past 12 months that includes identifying, assessing, and mitigating the risks associated with changes that could impact the internal control environment.	No exceptions noted.
Monitoring Activities			
CC4.1 - COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.			

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-008	The compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	Inquired of the Director of Information Security to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
		Inspected the most recent risk assessment results to verify that the compliance committee maintains a corporate compliance program and functions as a centralized source for submitting potential risks and compliance issues.	No exceptions noted.
CTL-009	Quarterly, the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy and reports directly to the board of directors' audit committee.	Inquired of the Director of Information Security to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.
		Inspected the compliance committee meeting agendas for a sample of quarters to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.
CTL-018	Annually, control self-assessments are performed by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity are in place and operating effectively. Corrective actions are taken based on relevant findings of the annual control self-assessment and tracked to resolution.	Inquired of the Director of Information Security to verify that control self-assessments were performed by management on an annual basis to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the cyber self-assessment results and corrective action plan tracking tool to verify that control self-assessments were performed within the past 12 months by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
CTL-023	Quarterly, network vulnerability scans are performed to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans are remediated as determined by management review.	Inquired of the Director of Information Security to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
		Inspected the network vulnerability scans for a sample of quarters to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
CTL-024	Annually, a penetration test is performed to identify potential system security vulnerabilities. Vulnerabilities identified during the penetration test are remediated as determined by management review.	Inquired of the Director of Information Security to verify that a penetration test was performed to identify potential system security vulnerabilities on an annual basis. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
		Inspected the penetration test report and management review to verify that a penetration test was performed to identify potential system security vulnerabilities within the past 12 months. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC4.2 - COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.			
CTL-009	Quarterly, the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy and reports directly to the board of directors' audit committee.	Inquired of the Director of Information Security to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis, and reports directly to the board of directors' audit committee.	No exceptions noted.
		Inspected the compliance committee meeting agendas for a sample of quarters to verify that the compliance committee meets to evaluate risk and compliance issues as they pertain to security, availability, confidentiality, and privacy on a quarterly basis and reports directly to the board of directors' audit committee.	No exceptions noted.
CTL-018	Annually, control self-assessments are performed by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity are in place and operating effectively. Corrective actions are taken based on relevant findings of the annual control self-assessment and tracked to resolution.	Inquired of the Director of Information Security to verify that control self-assessments were performed by management on an annual basis to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
		Inspected the cyber self-assessment results and corrective action plan tracking tool to verify that control self-assessments were performed within the past 12 months by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-023	Quarterly, network vulnerability scans are performed to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans are remediated as determined by management review.	Inquired of the Director of Information Security to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
		Inspected the network vulnerability scans for a sample of quarters to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
CTL-024	Annually, a penetration test is performed to identify potential system security vulnerabilities. Vulnerabilities identified during the penetration test are remediated as determined by management review.	Inquired of the Director of Information Security to verify that a penetration test was performed to identify potential system security vulnerabilities on an annual basis. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
		Inspected the penetration test report and management review to verify that a penetration test was performed to identify potential system security vulnerabilities within the past 12 months. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
Control Activities			
CC5.1 - COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.			

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-018	Annually, control self-assessments are performed by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity are in place and operating effectively. Corrective actions are taken based on relevant findings of the annual control self-assessment and tracked to resolution.	Inquired of the Director of Information Security to verify that control self-assessments were performed by management on an annual basis to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
		Inspected the cyber self-assessment results and corrective action plan tracking tool to verify that control self-assessments were performed within the past 12 months by management to gain assurance that controls related to the security, availability, confidentiality, and processing integrity were in place and operating effectively. Corrective actions were taken based on relevant findings of the annual control self-assessment and tracked to resolution.	No exceptions noted.
CTL-024	Annually, a penetration test is performed to identify potential system security vulnerabilities. Vulnerabilities identified during the penetration test are remediated as determined by management review.	Inquired of the Director of Information Security to verify that a penetration test was performed to identify potential system security vulnerabilities on an annual basis. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
		Inspected the penetration test report and management review to verify that a penetration test was performed to identify potential system security vulnerabilities within the past 12 months. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
CTL-040	Business objectives are specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	Inquired of the Director of Information Security to verify that business objectives were specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the annual risk assessment to verify that business objectives were specified in the annual risk assessment to enable the identification and assessment of risks related to the business's objectives.	No exceptions noted.
CTL-045	Annually, management performs a risk assessment that includes identifying, assessing, and mitigating the risks associated with changes that could impact the internal control environment.	Inquired of the Director of Information Security to verify that management performed a risk assessment on an annual basis that includes identifying, assessing, and mitigating the risks associated with changes that could impact the internal control environment.	No exceptions noted.
		Inspected the risk assessment to verify that management performed a risk assessment within the past 12 months that includes identifying, assessing, and mitigating the risks associated with changes that could impact the internal control environment.	No exceptions noted.
CTL-046	A disaster recovery plan is in place that defines recovery roles and responsibilities and identifies critical applications, operating systems, personnel, data files, and time frames needed to recover in the event of a disaster.	Inquired of the Director of Information Security to verify that a disaster recovery plan was in place that defines recovery roles and responsibilities and identifies critical applications, operating systems, personnel, data files, and time frames needed to recover in the event of a disaster.	No exceptions noted.
		Inspected the disaster recovery plan to verify that a disaster recovery plan was in place that defines recovery roles and responsibilities and identifies critical applications, operating systems, personnel, data files, and time frames needed to recover in the event of a disaster.	No exceptions noted.
CTL-047	Annually, the DR plan is tested and updated.	Inquired of the Director of Information Security to verify that the DR plan was tested and updated on an annual basis.	No exceptions noted.
		Inspected the disaster recovery tests to verify that the DR plan was tested and updated within the past 12 months.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC5.2 - COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.			
CTL-002	A formal policy is in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	Inquired of the Director of Information Security to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
		Inspected the Code of Conduct and corporate intranet to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
CTL-017	Information security policies and procedures are documented and define the information security rules and requirements for the service environment.	Inquired of the Director of Information Security to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
		Inspected the System & Information Integrity policy and procedures to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
CTL-019	The security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	Inquired of the Director of Information Security to verify that the security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	No exceptions noted.
		Inspected the subscriptions by the security owners to industry security bulletins to verify that the security owner subscribes to industry security bulletins and email alerts and uses them to monitor the impact of emerging technologies and security on the production systems.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-026	Security incident response policies and procedures are documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	Inquired of the Director of Information Security to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
		Inspected the incident response procedure policy and procedures to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
CTL-027	An incident response plan is in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP is reviewed and approved at least annually.	Inquired of the Director of Information Security to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
		Inspected the Incident Response Plan to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
CTL-038	A risk management policy is in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	Inquired of the Director of Information Security to verify that a risk management policy was in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	No exceptions noted.
		Inspected the Risk Assessment Policy to verify that a risk management policy was in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-048	Policies and procedures are maintained via the corporate intranet to guide personnel on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to guide personnel on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies and procedures available on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to guide personnel on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-049	Policies and procedures are in place regarding the management of data including the classification, retention, and destruction of confidential information.	Inquired of the Director of Information Security to verify that policies and procedures were in place regarding the management of data including the classification, retention, and destruction of confidential information.	No exceptions noted.
		Inspected the Asset Management and Disposal Policy to verify that policies and procedures were in place regarding the management of data including the classification, retention, and destruction of confidential information.	No exceptions noted.
CC5.3 - COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.			
CTL-002	A formal policy is in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	Inquired of the Director of Information Security to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.
		Inspected the Code of Conduct and corporate intranet to verify that a formal policy was in place and made available through the corporate intranet that defines the responsibilities of personnel for the prevention, detection, and reporting of bribery or corruption.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-011	Formal job descriptions are in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	Inquired of the Director of Information Security to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
		Inspected the relevant job descriptions to verify that formal job descriptions were in place defining roles and responsibilities for personnel responsible for protecting private and confidential information.	No exceptions noted.
CTL-017	Information security policies and procedures are documented and define the information security rules and requirements for the service environment.	Inquired of the Director of Information Security to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
		Inspected the System & Information Integrity policy and procedures to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
CTL-020	A SIEM or centralized log management tool is configured to monitor to network and log security events. The SIEM or centralized log management tool is configured to alert personnel when events exceed predefined thresholds.	Inquired of the Director of Information Security to verify that a SIEM or centralized log management tool was configured to monitor to network and log security events. The SIEM or centralized log management tool was configured to alert personnel when events exceed predefined thresholds.	No exceptions noted.
		Inspected the SIEM and centralized log management tool to verify that a SIEM or centralized log management tool was configured to monitor to network and log security events. The SIEM or centralized log management tool was configured to alert personnel when events exceed predefined thresholds.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-026	Security incident response policies and procedures are documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	Inquired of the Director of Information Security to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
		Inspected the incident response procedure policy and procedures to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
CTL-027	An incident response plan is in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP is reviewed and approved at least annually.	Inquired of the Director of Information Security to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
		Inspected the Incident Response Plan to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
CTL-038	A risk management policy is in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	Inquired of the Director of Information Security to verify that a risk management policy was in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	No exceptions noted.
		Inspected the Risk Assessment Policy to verify that a risk management policy was in place that standardizes the process for identifying, assessing, rating, assigning, and mitigating risks and vulnerabilities.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-048	Policies and procedures are maintained via the corporate intranet to guide personnel on organizational roles and responsibilities to meet business and security objectives.	Inquired of the Director of Information Security to verify that policies and procedures were maintained via the corporate intranet to guide personnel on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
		Inspected the policies and procedures available on the corporate intranet to verify that policies and procedures were maintained via the corporate intranet to guide personnel on organizational roles and responsibilities to meet business and security objectives.	No exceptions noted.
CTL-049	Policies and procedures are in place regarding the management of data including the classification, retention, and destruction of confidential information.	Inquired of the Director of Information Security to verify that policies and procedures were in place regarding the management of data including the classification, retention, and destruction of confidential information.	No exceptions noted.
		Inspected the Asset Management and Disposal Policy to verify that policies and procedures were in place regarding the management of data including the classification, retention, and destruction of confidential information.	No exceptions noted.
CTL-050	Annually, organizational policies and procedures are reviewed and updated to ensure that policies and procedures are current and accurate.	Inquired of the Director of Information Security to verify that organizational policies and procedures were reviewed and updated to ensure that policies and procedures were current and accurate on an annual basis.	No exceptions noted.
		Inspected the policies and procedures to verify that organizational policies and procedures were reviewed and updated to ensure that policies and procedures were current and accurate within the past 12 months.	No exceptions noted.
Logical and Physical Access Controls			
CC6.1 The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.			

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-017	Information security policies and procedures are documented and define the information security rules and requirements for the service environment.	Inquired of the Director of Information Security to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
		Inspected the System & Information Integrity policy and procedures to verify that information security policies and procedures were documented and define the information security rules and requirements for the service environment.	No exceptions noted.
CTL-051	A formal inventory of production system assets is maintained by management.	Inquired of the Director of Information Security to verify that a formal inventory of production system assets was maintained by management.	No exceptions noted.
		Inspected the asset inventory to verify that a formal inventory of production system assets was maintained by management.	No exceptions noted.
CTL-052	The network is segmented to prevent unauthorized access to customer data.	Inquired of the Director of Information Security to verify that the network was segmented to prevent unauthorized access to customer data.	No exceptions noted.
		Inspected the network diagram to verify that the network was segmented to prevent unauthorized access to customer data.	No exceptions noted.
CTL-053	Access to the network domain is restricted via unique user ID and password.	Inquired of the Director of Information Security to verify that access to the network domain was restricted via unique user ID and password.	No exceptions noted.
		Inspected the network domain restrictions to verify that access to the network domain was restricted via unique user ID and password.	No exceptions noted.
CTL-054	Network domain authentication settings are in place to enforce the following password parameters: enforce password length, complexity, history, and account lockout.	Inquired of the Director of Information Security to verify that network domain authentication settings were in place to enforce the following password parameters: enforce password length, complexity, history, and account lockout.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the network domain authentication settings to verify that network domain authentication settings were in place to enforce the following password parameters: enforce password length, complexity, history, and account lockout.	No exceptions noted.
CTL-055	Single sign-on is configured to inherit authentication configurations from AD.	Inquired of the Director of Information Security to verify that single sign-on was configured to inherit authentication configurations from AD.	No exceptions noted.
		Inspected the AD integration configurations to verify that single sign-on was configured to inherit authentication configurations from AD.	No exceptions noted.
CTL-056	Access to the IdP is restricted via a unique username and password and requires MFA.	Inquired of the Director of Information Security to verify that access to the IdP was restricted via a unique username and password and requires MFA.	No exceptions noted.
		Inspected the MFA requirement to verify that access to the IdP was restricted via a unique username and password and requires MFA.	No exceptions noted.
CTL-057	Administrative access to the IdP is restricted to authorized personnel.	Inquired of the Director of Information Security to verify that administrative access to the IdP was restricted to authorized personnel.	No exceptions noted.
		Inspected the administrator listing to verify that administrative access to the IdP was restricted to authorized personnel.	No exceptions noted.
CTL-058	Access to the AWS cloud environment is restricted to authorized personnel.	Inquired of the Director of Information Security to verify that access to the AWS cloud environment was restricted to authorized personnel.	No exceptions noted.
		Inspected the AWS administrator listings to verify that access to the AWS cloud environment was restricted to authorized personnel.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-059	Administrative access to the AWS management console is restricted to authorized personnel.	Inquired of the Director of Information Security to verify that administrative access to the AWS management console was restricted to authorized personnel.	No exceptions noted.
		Inspected the AWS administrator listings to verify that administrative access to the AWS management console was restricted to authorized personnel.	No exceptions noted.
CTL-060	Access to the production systems is restricted to authorized personnel with a valid MFA token.	Inquired of the Director of Information Security to verify that access to the production systems was restricted to authorized personnel with a valid MFA token.	No exceptions noted.
		Inspected the MFA requirements to verify that access to the production systems was restricted to authorized personnel with a valid MFA token.	No exceptions noted.
CTL-061	Administrative access to the production systems is restricted to authorized personnel.	Inquired of the Director of Information Security to verify that administrative access to the production systems was restricted to authorized personnel.	No exceptions noted.
		Inspected the production systems administrator listings to verify that administrative access to the production systems was restricted to authorized personnel.	No exceptions noted.
CTL-062	Access to the in-scope applications is restricted via a unique username and password.	Inquired of the Director of Information Security to verify that access to the in-scope applications was restricted via a unique username and password.	No exceptions noted.
		Inspected the application login prompts to verify that access to the in-scope applications was restricted via a unique username and password.	No exceptions noted.
CTL-063	Applications are configured to enforce password length and complexity.	Inquired of the Director of Information Security to verify that applications were configured to enforce password length and complexity.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the application password requirements and configurations to verify that applications were configured to enforce password length and complexity.	No exceptions noted.
CTL-064	Administrative access to the in-scope applications is restricted to authorized personnel.	Inquired of the Director of Information Security to verify that administrative access to the in-scope applications was restricted to authorized personnel.	No exceptions noted.
		Inspected the application administrator listings to verify that administrative access to the in-scope applications was restricted to authorized personnel.	No exceptions noted.
CTL-065	A password management tool is in place to protect and store credentials to privileged accounts.	Inquired of the Director of Information Security to verify that a password management tool was in place to protect and store credentials to privileged accounts.	No exceptions noted.
		Inspected the password management tool to verify that a password management tool was in place to protect and store credentials to privileged accounts.	No exceptions noted.
CTL-066	Administrative access to the password management tool is restricted to authorized personnel.	Inquired of the Director of Information Security to verify that administrative access to the password management tool was restricted to authorized personnel.	No exceptions noted.
		Inspected the password management tool to verify that administrative access to the password management tool was restricted to authorized personnel.	No exceptions noted.
CTL-125	Access to the PAM solution is restricted to authorized users via SSO with enforced MFA.	Inquired of the Director of Information Security to verify that access to the PAM solution was restricted to authorized users via SSO with enforced MFA.	No exceptions noted.
		Inspected the SAML certificate and MFA configurations to verify that access to the PAM solution was restricted to authorized users via SSO with enforced MFA.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC6.2 Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.			
CTL-067	User access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned.	Inquired of the Director of Information Security to verify that user access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned.	No exceptions noted.
		Inspected the user access for system components for a sample of employees onboarded during the examination period to verify that user access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned.	No exceptions noted.
CTL-068	User access to in-scope system components is revoked within 24 hours of termination.	Inquired of the Director of Information Security to verify that user access to in-scope system components was revoked within 24 hours of termination.	No exceptions noted.
		Inspected the user access logs for a sample of terminated employees to verify that user access to in-scope system components was revoked within 24 hours of termination.	No exceptions noted.
CTL-069	Quarterly, access reviews are performed to ensure that privileged roles are restricted to authorized personnel.	Inquired of the Director of Information Security to verify that access reviews were performed on a quarterly basis to ensure that privileged roles were restricted to authorized personnel.	No exceptions noted.
		Inspected the access reviews for a sample of quarters to verify that access reviews were performed on a quarterly basis to ensure that privileged roles were restricted to authorized personnel.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC6.3 The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.			
CTL-067	User access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned.	Inquired of the Director of Information Security to verify that user access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned.	No exceptions noted.
		Inspected the user access for system components for a sample of employees onboarded during the examination period to verify that user access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned.	No exceptions noted.
CTL-068	User access to in-scope system components is revoked within 24 hours of termination.	Inquired of the Director of Information Security to verify that user access to in-scope system components was revoked within 24 hours of termination.	No exceptions noted.
		Inspected the user access logs for a sample of terminated employees to verify that user access to in-scope system components was revoked within 24 hours of termination.	No exceptions noted.
CTL-069	Quarterly, access reviews are performed to ensure that privileged roles are restricted to authorized personnel.	Inquired of the Director of Information Security to verify that access reviews were performed on a quarterly basis to ensure that privileged roles were restricted to authorized personnel.	No exceptions noted.
		Inspected the access reviews for a sample of quarters to verify that access reviews were performed on a quarterly basis to ensure that privileged roles were restricted to authorized personnel.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC6.4 The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.			
CTL-071	Annually, management obtains and reviews third-party examination reports for subservice organizations to ensure controls are in compliance of organizational security expectations.	Inquired of the Director of Information Security to verify that management obtains and reviews third-party examination reports on an annual basis for subservice organizations to ensure controls were in compliance of organizational security expectations.	No exceptions noted.
		Inspected the third party examination reports with management review to verify that management obtained and reviewed third-party examination reports within the past 12 months for subservice organizations to ensure controls were in compliance of organizational security expectations.	No exceptions noted.
CC6.5 The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.			
CTL-072	Electronic media containing confidential information is purged or destroyed and certificates of destruction are issued for each device destroyed.	Inquired of the Director of Information Security to verify that electronic media containing confidential information was purged or destroyed and certificates of destruction were issued for each device destroyed.	No exceptions noted.
		Inspected the certificate of destruction to verify that electronic media containing confidential information was purged or destroyed and certificates of destruction were issued for each device destroyed.	No exceptions noted.
CTL-073	Data retention and disposal policies are in place that define requirements for the retention and secure disposal of confidential information and assets.	Inquired of the Director of Information Security to verify that data retention and disposal policies were in place that define requirements for the retention and secure disposal of confidential information and assets.	No exceptions noted.
		Inspected the data retention and disposal policies to verify that data retention and disposal policies were in place that define requirements for the retention and secure disposal of confidential information and assets.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC6.6 The entity implements logical access security measures to protect against threats from sources outside its system boundaries.			
CTL-021	An IDS is configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS is configured to alert personnel when potential intrusions exceed predefined thresholds.	Inquired of the Director of Information Security to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
		Inspected the IDS configurations to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
CTL-074	Secure data transmission protocols are used to encrypt confidential and sensitive data when transmitted over public networks.	Inquired of the Director of Information Security to verify that secure data transmission protocols were used to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
		Inspected the secure data transmission protocols used to verify that secure data transmission protocols were used to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
CTL-075	Security groups are configured to restrict inbound traffic.	Inquired of the Director of Information Security to verify that security groups were configured to restrict inbound traffic.	No exceptions noted.
		Inspected the security group rules to verify that security groups were configured to restrict inbound traffic.	No exceptions noted.
CTL-076	A WAF is configured to monitor the network on a continuous basis.	Inquired of the Director of Information Security to verify that a WAF was configured to monitor the network on a continuous basis.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the WAF configurations to verify that a WAF was configured to monitor the network on a continuous basis.	No exceptions noted.
CTL-078	Web sessions are encrypted using TLS.	Inquired of the Director of Information Security to verify that web sessions were encrypted using TLS.	No exceptions noted.
		Inspected the encryption for web sessions to verify that web sessions were encrypted using TLS.	No exceptions noted.
CTL-094	The organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	Inquired of the Director of Information Security to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
		Inspected the patch deployment to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
CC6.7 The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.			
CTL-074	Secure data transmission protocols are used to encrypt confidential and sensitive data when transmitted over public networks.	Inquired of the Director of Information Security to verify that secure data transmission protocols were used to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
		Inspected the secure data transmission protocols used to verify that secure data transmission protocols were used to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
CTL-075	Security groups are configured to restrict inbound traffic.	Inquired of the Director of Information Security to verify that security groups were configured to restrict inbound traffic.	No exceptions noted.
		Inspected the security group rules to verify that security groups were configured to restrict inbound traffic.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-076	A WAF is configured to monitor the network on a continuous basis.	Inquired of the Director of Information Security to verify that a WAF was configured to monitor the network on a continuous basis.	No exceptions noted.
		Inspected the WAF configurations to verify that a WAF was configured to monitor the network on a continuous basis.	No exceptions noted.
CTL-078	Web sessions are encrypted using TLS.	Inquired of the Director of Information Security to verify that web sessions were encrypted using TLS.	No exceptions noted.
		Inspected the encryption for web sessions to verify that web sessions were encrypted using TLS.	No exceptions noted.
CC6.8 The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.			
CTL-021	An IDS is configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS is configured to alert personnel when potential intrusions exceed predefined thresholds.	Inquired of the Director of Information Security to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
		Inspected the IDS configurations to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
CTL-080	Endpoint protection software is installed on workstations and production systems to protect from malicious software and prevent against threats from external sources.	Inquired of the Director of Information Security to verify that endpoint protection software was installed on workstations and production systems to protect from malicious software and prevent against threats from external sources.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the endpoint protection software policies to verify that endpoint protection software was installed on workstations and production systems to protect from malicious software and prevent against threats from external sources.	No exceptions noted.
CTL-081	Data backups are encrypted and stored in a secondary location.	Inquired of the Director of Information Security to verify that data backups were encrypted and stored in a secondary location.	No exceptions noted.
		Inspected the backup encryption to verify that data backups were encrypted and stored in a secondary location.	No exceptions noted.
CTL-094	The organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	Inquired of the Director of Information Security to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
		Inspected the patch deployment to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
System Operations			
CC7.1 To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.			
CTL-020	A SIEM or centralized log management tool is configured to monitor to network and log security events. The SIEM or centralized log management tool is configured to alert personnel when events exceed predefined thresholds.	Inquired of the Director of Information Security to verify that a SIEM or centralized log management tool was configured to monitor to network and log security events. The SIEM or centralized log management tool was configured to alert personnel when events exceed predefined thresholds.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the SIEM and centralized log management tool to verify that a SIEM or centralized log management tool was configured to monitor to network and log security events. The SIEM or centralized log management tool was configured to alert personnel when events exceed predefined thresholds.	No exceptions noted.
CTL-021	An IDS is configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS is configured to alert personnel when potential intrusions exceed predefined thresholds.	Inquired of the Director of Information Security to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
		Inspected the IDS configurations to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
CTL-022	An uptime management tool is configured to monitor application and infrastructure system availability, resource capacity, and performance metrics. The uptime management tool is configured to alert personnel when performance exceed predefined thresholds.	Inquired of the Director of Information Security to verify that an uptime management tool was configured to monitor application and infrastructure system availability, resource capacity, and performance metrics. The uptime management tool was configured to alert personnel when performance exceed predefined thresholds.	No exceptions noted.
		Inspected the monitoring dashboard, alert configurations, and a recent alert to verify that an uptime management tool was configured to monitor application and infrastructure system availability, resource capacity, and performance metrics. The uptime management tool was configured to alert personnel when performance exceed predefined thresholds.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-023	Quarterly, network vulnerability scans are performed to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans are remediated as determined by management review.	Inquired of the Director of Information Security to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
		Inspected the network vulnerability scans for a sample of quarters to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
CTL-024	Annually, a penetration test is performed to identify potential system security vulnerabilities. Vulnerabilities identified during the penetration test are remediated as determined by management review.	Inquired of the Director of Information Security to verify that a penetration test was performed to identify potential system security vulnerabilities on an annual basis. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
		Inspected the penetration test report and management review to verify that a penetration test was performed to identify potential system security vulnerabilities within the past 12 months. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
CTL-025	File integrity monitoring software is installed on systems to monitor and log changes to critical system or configuration files.	Inquired of the Director of Information Security to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
		Inspected the file integrity monitoring software to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-094	The organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	Inquired of the Director of Information Security to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
		Inspected the patch deployment to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
CC7.2 The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.			
CTL-020	A SIEM or centralized log management tool is configured to monitor to network and log security events. The SIEM or centralized log management tool is configured to alert personnel when events exceed predefined thresholds.	Inquired of the Director of Information Security to verify that a SIEM or centralized log management tool was configured to monitor to network and log security events. The SIEM or centralized log management tool was configured to alert personnel when events exceed predefined thresholds.	No exceptions noted.
		Inspected the SIEM and centralized log management tool to verify that a SIEM or centralized log management tool was configured to monitor to network and log security events. The SIEM or centralized log management tool was configured to alert personnel when events exceed predefined thresholds.	No exceptions noted.
CTL-021	An IDS is configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS is configured to alert personnel when potential intrusions exceed predefined thresholds.	Inquired of the Director of Information Security to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the IDS configurations to verify that an IDS was configured to provide continuous monitoring and analysis of network traffic and system events to identify potential security threats on system resources. The IDS was configured to alert personnel when potential intrusions exceed predefined thresholds.	No exceptions noted.
CTL-022	An uptime management tool is configured to monitor application and infrastructure system availability, resource capacity, and performance metrics. The uptime management tool is configured to alert personnel when performance exceed predefined thresholds.	Inquired of the Director of Information Security to verify that an uptime management tool was configured to monitor application and infrastructure system availability, resource capacity, and performance metrics. The uptime management tool was configured to alert personnel when performance exceed predefined thresholds.	No exceptions noted.
		Inspected the monitoring dashboard, alert configurations, and a recent alert to verify that an uptime management tool was configured to monitor application and infrastructure system availability, resource capacity, and performance metrics. The uptime management tool was configured to alert personnel when performance exceed predefined thresholds.	No exceptions noted.
CTL-023	Quarterly, network vulnerability scans are performed to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans are remediated as determined by management review.	Inquired of the Director of Information Security to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.
		Inspected the network vulnerability scans for a sample of quarters to verify that network vulnerability scans were performed on a quarterly basis to identify potential risks and vulnerabilities associated with insecure services and unpatched system components. Vulnerabilities identified during the quarterly vulnerability scans were remediated as determined by management review.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-024	Annually, a penetration test is performed to identify potential system security vulnerabilities. Vulnerabilities identified during the penetration test are remediated as determined by management review.	Inquired of the Director of Information Security to verify that a penetration test was performed to identify potential system security vulnerabilities on an annual basis. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
		Inspected the penetration test report and management review to verify that a penetration test was performed to identify potential system security vulnerabilities within the past 12 months. Vulnerabilities identified during the penetration test were remediated as determined by management review.	No exceptions noted.
CTL-025	File integrity monitoring software is installed on systems to monitor and log changes to critical system or configuration files.	Inquired of the Director of Information Security to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
		Inspected the file integrity monitoring software to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
CTL-094	The organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	Inquired of the Director of Information Security to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.
		Inspected the patch deployment to verify that the organization employs automated patch management tools to track system patch status and deploy security updates to endpoints.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC7.3 The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.			
CTL-026	Security incident response policies and procedures are documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	Inquired of the Director of Information Security to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
		Inspected the incident response procedure policy and procedures to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
CTL-027	An incident response plan is in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP is reviewed and approved at least annually.	Inquired of the Director of Information Security to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
		Inspected the Incident Response Plan to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
CTL-082	A ticketing system is utilized to document, track, and monitor incidents through resolution.	Inquired of the Director of Information Security to verify that a ticketing system was utilized to document, track, and monitor incidents through resolution.	No exceptions noted.
		Inspected the monitoring of the ticketing system to verify that a ticketing system was utilized to document, track, and monitor incidents through resolution.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC7.4 The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.			
CTL-026	Security incident response policies and procedures are documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	Inquired of the Director of Information Security to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
		Inspected the incident response procedure policy and procedures to verify that security incident response policies and procedures were documented to provide personnel with guidance for detecting, responding to, and recovering from security events and incidents.	No exceptions noted.
CTL-027	An incident response plan is in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP is reviewed and approved at least annually.	Inquired of the Director of Information Security to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
		Inspected the Incident Response Plan to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
CTL-082	A ticketing system is utilized to document, track, and monitor incidents through resolution.	Inquired of the Director of Information Security to verify that a ticketing system was utilized to document, track, and monitor incidents through resolution.	No exceptions noted.
		Inspected the monitoring of the ticketing system to verify that a ticketing system was utilized to document, track, and monitor incidents through resolution.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-083	Annually, the incident response plan is tested to assess the effectiveness of the incident response program.	Inquired of the Director of Information Security to verify that the incident response plan was tested on an annual basis to assess the effectiveness of the incident response program.	No exceptions noted.
		Inspected the annual incident response test and training to verify that the incident response plan was tested within the past 12 months to assess the effectiveness of the incident response program.	No exceptions noted.
CTL-084	Annually, penetration testing is performed to identify potential system security vulnerabilities.	Inquired of the Director of Information Security to verify that penetration testing was performed on an annual basis to identify potential system security vulnerabilities.	No exceptions noted.
		Inspected the penetration test report to verify that penetration testing was performed within the past 12 months to identify potential system security vulnerabilities.	No exceptions noted.
CC7.5 The entity identifies, develops, and implements activities to recover from identified security incidents.			
CTL-027	An incident response plan is in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP is reviewed and approved at least annually.	Inquired of the Director of Information Security to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
		Inspected the Incident Response Plan to verify that an incident response plan was in place to provide guidance to personnel on procedures for identifying, responding to, evaluating, and treating breaches and reported security events or incidents. The IRP was reviewed and approved at least annually.	No exceptions noted.
CTL-047	Annually, the DR plan is tested and updated.	Inquired of the Director of Information Security to verify that the DR plan was tested and updated on an annual basis.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the disaster recovery tests to verify that the DR plan was tested and updated within the past 12 months.	No exceptions noted.
CTL-085	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Director of Information Security to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
Change Management			
CC8.1 The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
CTL-025	File integrity monitoring software is installed on systems to monitor and log changes to critical system or configuration files.	Inquired of the Director of Information Security to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
		Inspected the file integrity monitoring software to verify that file integrity monitoring software was installed on systems to monitor and log changes to critical system or configuration files.	No exceptions noted.
CTL-086	Policies and procedures are maintained to guide personnel on the systems development process and the mitigation of risks associated with changes.	Inquired of the Director of Information Security to verify that policies and procedures were maintained to guide personnel on the systems development process and the mitigation of risks associated with changes.	No exceptions noted.
		Inspected the Contingency Planning and Configuration Management policies to verify that policies and procedures were maintained to guide personnel on the systems development process and the mitigation of risks associated with changes.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-087	Version control software is utilized to restrict access to source code and provide rollback capabilities.	Inquired of the Director of Information Security to verify that version control software was utilized to restrict access to source code and provide rollback capabilities.	No exceptions noted.
		Inspected the version control software to verify that version control software was utilized to restrict access to source code and provide rollback capabilities.	No exceptions noted.
CTL-088	Changes to the applications are tested and approved by the QA team prior to deployment into production.	Inquired of the Director of Information Security to verify that changes to the applications were tested and approved by the QA team prior to deployment into production.	No exceptions noted.
		Inspected the application change tickets for a sample of change requests to verify that changes to the applications were tested and approved by the QA team prior to deployment into production.	No exceptions noted.
CTL-089	Code review by personnel other than the original developer is performed on changes to the applications prior to deploying to production.	Inquired of the Director of Information Security to verify that code review by personnel other than the original developer was performed on changes to the applications prior to deploying to production.	No exceptions noted.
		Inspected the code review for a sample of application change requests to verify that code review by personnel other than the original developer was performed on changes to the applications prior to deploying to production.	No exceptions noted.
CTL-090	Changes to the network configurations, servers, databases and cloud infrastructure are tested or have documented rollback plans. Test results or rollback plans are documented and maintained with the associated change request.	Inquired of the Director of Information Security to verify that changes to the network configurations, servers, databases and cloud infrastructure were tested or have documented rollback plans. Test results or rollback plans were documented and maintained with the associated change request.	No exceptions noted.